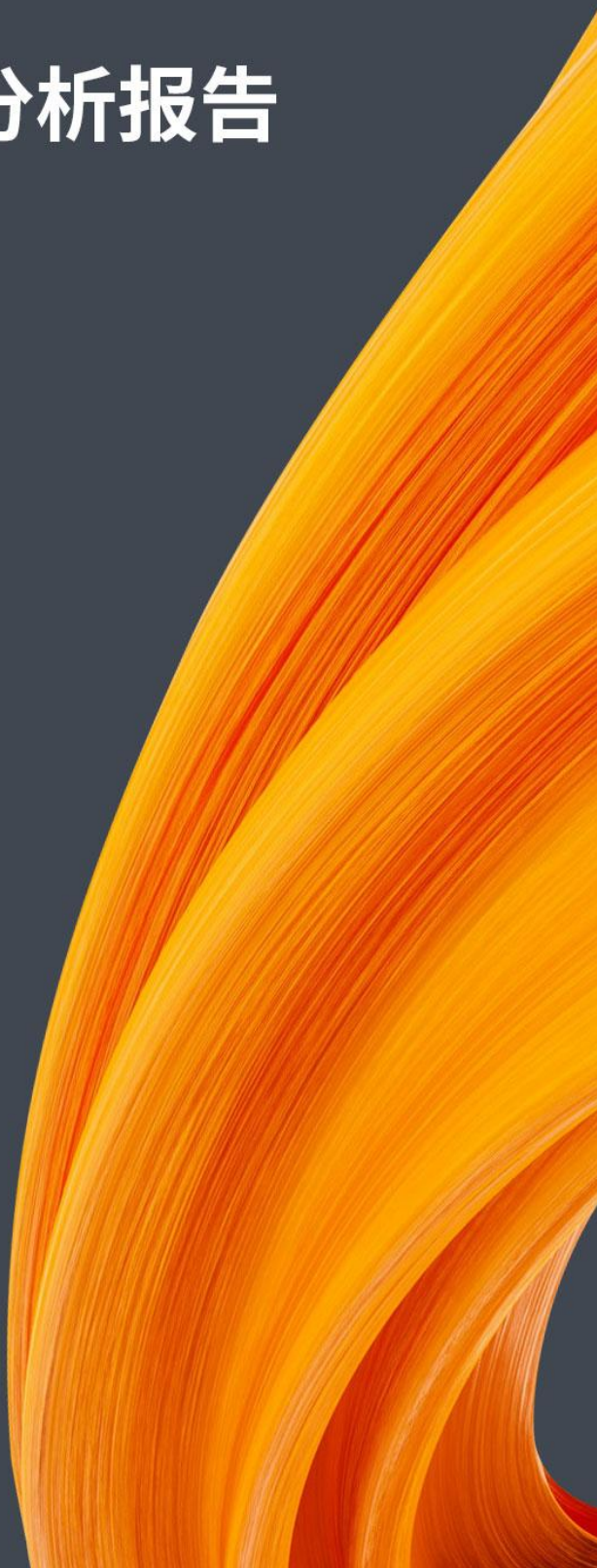
2022 上半年

区块链安全及反洗钱分析报告



SLOWMIST

目录

一、背景 3
1.1 区块链生态与监管 3
1.2 区块链安全态势 4
1.3 区块链反洗钱态势 6
二、区块链安全现状 12
2.1 区块链生态安全概览 12
2.1.1 公链赛道 12
2.1.1.1 DeFi 12
2.1.1.2 NFT 14
2.1.1.3 跨链桥 16
2.1.2 交易平台 17
2.1.3 其他 18
2.2 攻击手法概览 19
2.3 典型安全事件 21
2.3.1 Ronin Network 损失超 6.1 亿美元 21
2.3.2 Wormhole 损失超 3 亿美元 21
2.3.3 Beanstalk Farms 遭闪电贷和提案攻击 22
2.3.4 Harmony 损失超 1 亿美元 22
2.3.5 Pokemoney 发生 Rug Pull 22
2.3.6 Crypto.com 部分账户遭黑客攻击 22
2.3.7 Uniswap 空投钓鱼攻击 22
2.3.8 OpenSea 多名用户遭邮件钓鱼 23
2.3.9 ApeCoin 空投闪电贷套利 23
2.3.10 BAYC 官方 Discord 遭攻击 23
2.3.11 FEG 遭两次闪电贷攻击 23
2.3.12 Optimism 因合约漏洞损失 2000 万枚 OP 23

2.3.13 MM.finance 遭 DNS 劫持攻击 24
2.3.14 KLAYswap 遭到恶意前端攻击 24
2.3.15 Terra 生态崩溃 24
三、典型安全事件反洗钱分析 24
3.1 典型安全事件损失概览 25
3.2 工具及方法 26
3.2.1 基础工具 - MistTrack 26
3.2.2 拓展方法 - 数据分析 28
3.3 反洗钱分析详述 30
3.3.1 Ronin Network 30
3.3.2 Wormhole 36
3.3.3 Beanstalk 37
3.3.4 Harmony 39
3.3.5 Crypto.com 42
3.3.6 Uniswap Phishing 44
3.3.7 ApeCoin 空投闪电贷套利 46
3.3.8 BAYC 官方 Discord 遭攻击 47
3.3.9 FEGToken 48
3.3.10 Optimism 53
3.3.11 MM.finance 55
四、总结 58
五、免责声明 59
六、关于我们 60

本报告聚焦于 2022 年上半年区块链行业所发生的重大事件，主要介绍区块链行业各赛道的安全状况，延伸并提炼出上半年发生的典型安全事件以及常见攻击手法。接着对典型安全事件的被盗资金流向进行分析，并通过归纳总结，首次公布一种针对混币器资金追踪的高级分析方法。

一、背景

1.1 区块链生态与监管

近两年来，在疫情持续肆虐、经济衰退、能源短缺、地缘冲突升级、国际间竞争加剧等种种因素的影响之下，全球社会与经济发展遭遇了前所未有的挑战。与此同时，全球区块链行业也经历着一场不断加速的变革：区块链技术的效率、安全性和可扩展性得到不断改善，元宇宙、NFT 等新兴领域的兴起，使区块链行业正式迈入 3.0 时代。

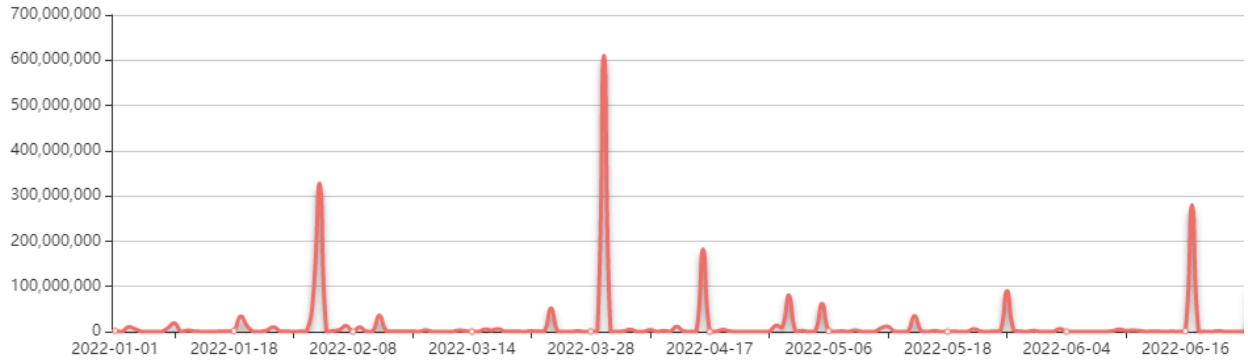
从政策监管来看，随着监管机构及大众对加密货币和区块链技术的了解程度越来越高，各国对加密货币领域的政策正在走向截然不同的路。各国政府关于加密货币监管的态度总体可分为三种：拥抱支持、模糊不定、严令禁止。尽管各国政府对于加密货币的态度不尽相同，但从上半年的政策来看，2022 年无疑是加密监管新纪元的开端，加密货币市场正在步向合规化。

从产业赋能来看，区块链产业发展机遇与挑战并存，区块链技术正在从“可用”走向“好用”，疫情推动各行业数字化转型的背景下，区块链正与传统行业加速融合，例如区块链“双碳”应用的爆发式增长，这不仅代表了全球在应对气候变化以及促进可持续发展方面的迫切需求，还代表了“绿色革命”与新兴技术的快速融合。除此之外，随着知识产权管理应用的强势崛起、新的行业联盟链层出不穷、区块链在数据等领域更多的应用落地等，都表明区块链在驱动各行业业务升级中发挥日益重要的作用。

从市场发展来看，一方面，由于价格暴跌、DeFi 协议崩溃和 CeFi 的破产，加密货币在上半年经历了令人难以置信的动荡；另一方面，许多新兴趋势和主题正在形成，加密货币用户和 Web3 开发人员的数量正在上升，元宇宙的形态正在渐渐显现。据 CoinMarketCap 数据显示，截至 6 月 30 日全球加密货币总市值超过 9051 亿美元，全球区块链市场整体上仍在蓬勃发展。

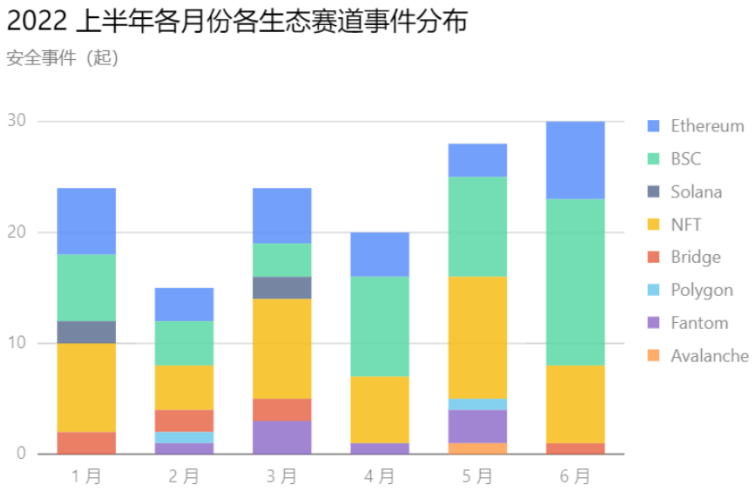
1.2 区块链安全态势

随着区块链行业发展态势整体越来越好，加密货币犯罪也越来越猖獗。根据慢雾区块链被黑事件档案库 (SlowMist Hacked)统计，截至 6 月 30 日，2022 上半年安全事件共187 件，损失高达 19.76 亿美元。



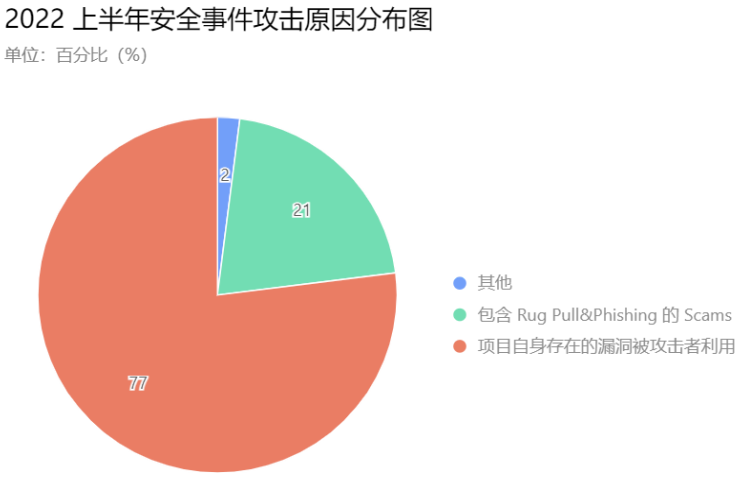
（2022 上半年安全事件）

从统计数据来看，上半年发生安全事件次数较多的月份主要在 5、6 月；从各生态来看，BSC 上安全事件发生最多；从赛道来看，损失最多的是跨链桥。

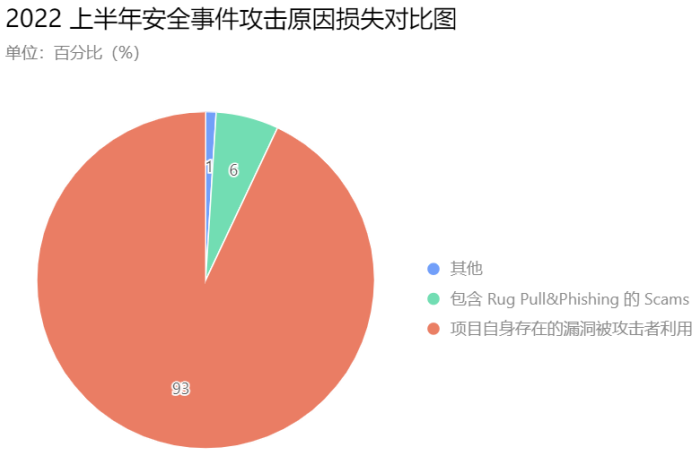


（2022 上半年各月份各生态赛道事件分布 ）

在这些安全事件中，约 77%（144 起）源于项目自身存在漏洞被攻击者利用，损失金额约 18.4 亿美元，占安全事件总损失的 93%；约 21%（39 起）源于包含 Phishing&Rug Pull 的 Scams，损失金额约 1.3 亿美元，占安全事件总损失的 6%。



（2022 上半年安全事件攻击原因分布图）



（2022 上半年安全事件攻击原因损失对比图）

1.3 区块链反洗钱态势

匿名性与不可逆是加密货币交易的天然属性，正是这样的原因，在加密货币犯罪频发的情况下，区块链反洗钱处于一个至关重要的位置，也是阻止黑客成功变现的最后防线。面对黑客无孔不入的威胁，不同的群体也不约而同的"组建"起反洗钱同盟，其中包括交易平台/资金管理平台/项目方、监管方和区块链安全公司。

2022 上半年，这些群体的反洗钱动态如下：

交易平台/资金管理平台/项目方

Tether：2022 上半年共计 屏蔽了 132 个 ETH 地址，这些地址上拥有的 USDT-ERC20 资产被冻结不可转移。

Circle：2022 上半年共计 屏蔽了 18 个 ETH 地址，这些地址上拥有的 USDC-ERC20 资金被冻结不可转移。

监管方

美国财政部：4 月 14 日制裁 Ronin Network 黑客（LAZARUS GROUP）相关的地址，5 月 6 日 制裁加密货币混币器 Blender，值得注意的是，美国财政部在此之前从未制裁过加密货币混币器。

区块链安全公司

Chainalysis：3 月 10 日，创建 SanctionsList 链上数据库合约，共计 制裁 31 个地址 。

SlowMist：4 月 27 日，MistTrack 反洗钱追踪系统 正式上线，专注于打击加密货 币洗钱活动。

众所周知，造成区块链安全事件的黑客、黑色产业链、欺诈者和 Rug Pull 项目方一直是洗钱的主力，其中最臭名昭著的莫过于朝鲜 LAZARUS GROUP 黑客组织，给区块链生态安全带来巨大的威胁。

根据开源情报和链上数据分析推测 LAZARUS GROUP 上半年的动态如下：

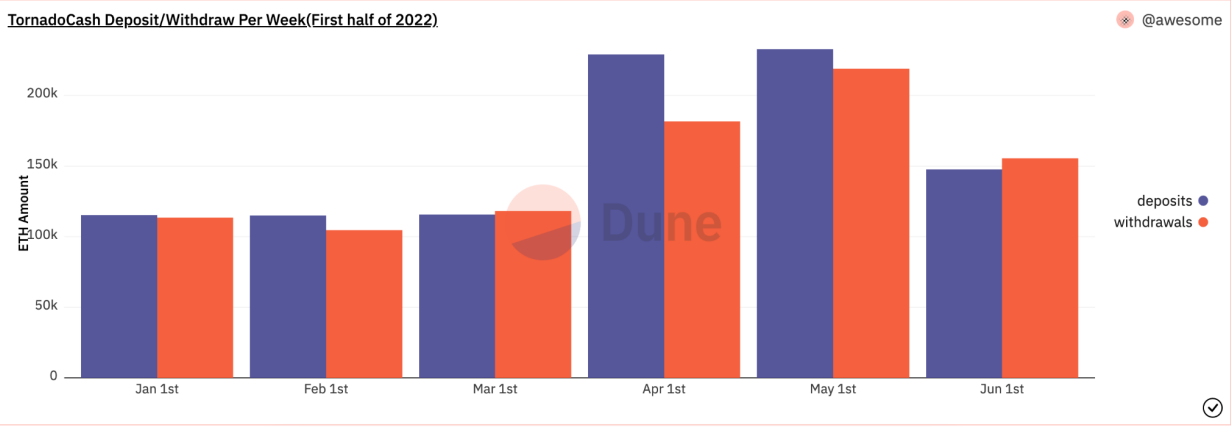
- 1 月 17 日，Crypto.com 的少数用户账户遭到未经授权提款。
- 2 月 8 日，The IRA Financial 的 Gemini 托管账户被恶意提款。
- 3 月 23 日，Ronin Network 跨链桥被盗成为加密货币领域损失最大的黑客攻击事件之一。

在这些与 LAZARUS GROUP 相关的安全事件中，我们可以通过他们成体系的洗钱手法发现他们的痕迹：

- 初期：将 ETH 链上的获利资金全部兑换为 ETH，并将所有的 ETH 分批转入 Tornado.Cash（大量）或者交易平台（少量）。
- 中期：从 Tornado.Cash 分批提款后兑换为 renBTC 代币跨链到 BTC 链。
- 后期：在 BTC 链上，从 renBTC 提款后汇总资金，并进一步转移到 Coinjoin 和混币器。

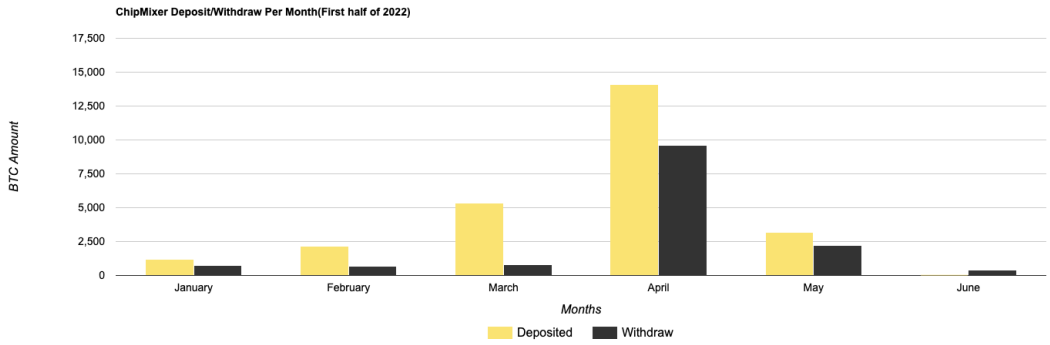
在黑客、黑色产业链、欺诈者和 Rug Pull 项目方洗钱过程中，自然少不了一些洗钱工具的帮忙，常见的洗钱工具有 ETH/BSC 链上的 Tornado.Cash，BTC 链上的 Coinjoin 工具（ChipMixer 等）、混币器（Blender、CryptoMixer 等）、隐私钱包（Wasabi、Samourai 等）、换币平台（ChangeNOW、SimpleSwap、FixedFloat 等）和一些交易平台。

一些常见洗钱工具上半年的存提款数据如下：



（Tornado.Cash 上半年存款/提款图）

Tornado.Cash：2022 上半年 用户共计存款 955,277 ETH（约 24.42亿美元）到 Tornado.Cash，共计从 Tornado.Cash 提款 892,573 ETH（约 22.49 亿美元）。



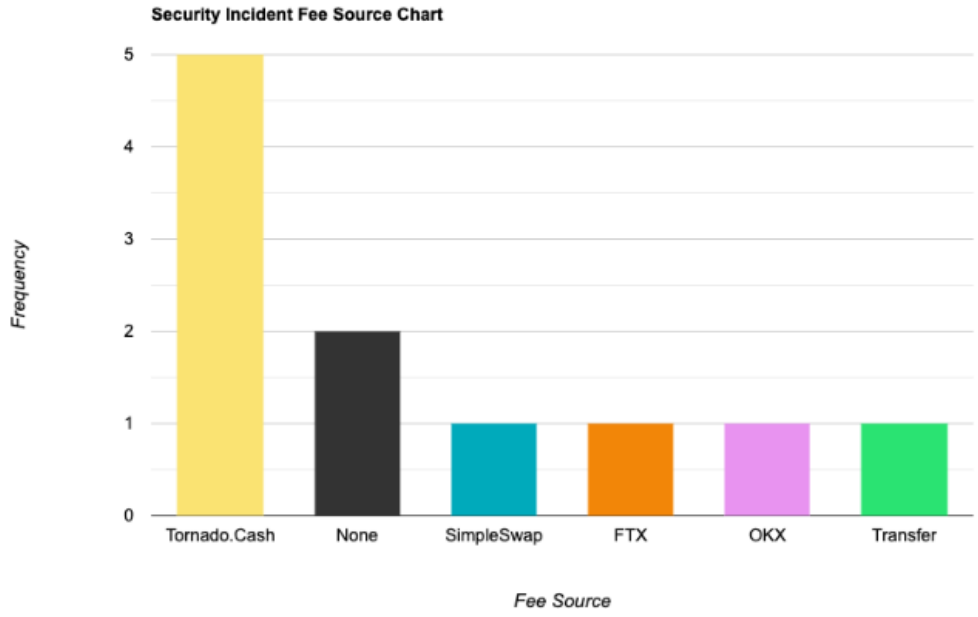
（ChipMixer 上半年存款/提款图 ）

ChipMixer：2022 上半年用户共计存款 26,021.89 BTC 到 ChipMixer，共计从 ChipMixer 提款 14,370.57 BTC。

Blender：LAZARUS GROUP 使用此混币器洗 Ronin Network 跨链桥被盗的钱，于 5 月 6 日被美国财政部制裁，目前站点已不可用。

在反洗钱分析过程中，始终存在着几个核心的问题：发起攻击的手续费来自哪里？洗钱的资金去了哪里？我们将通过上半年的典型安全事件来探索这两个问题。

发起攻击的手续费来自哪里？



（典型安全事件攻击手续费来源图）

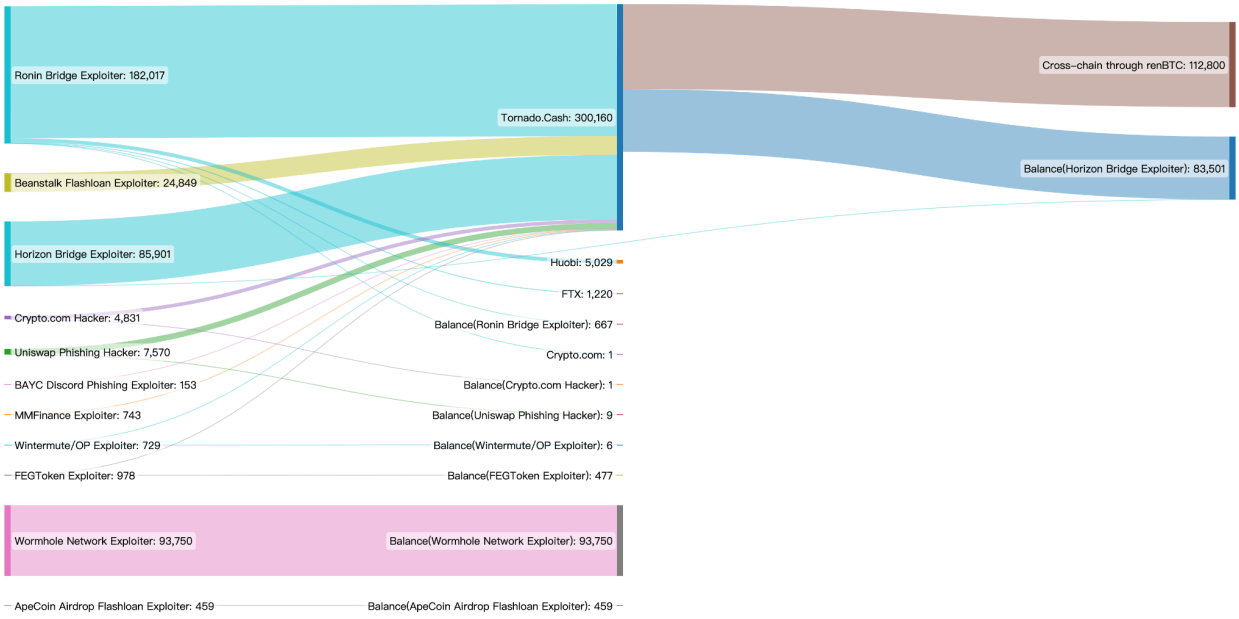
根据典型安全事件攻击手续费来源图，典型安全事件的攻击手续费大多都来自 Tornado.Cash 提款，也有从换币平台、交易平台提款或从其他个人地址转移的情况。

洗钱的资金去了哪里？

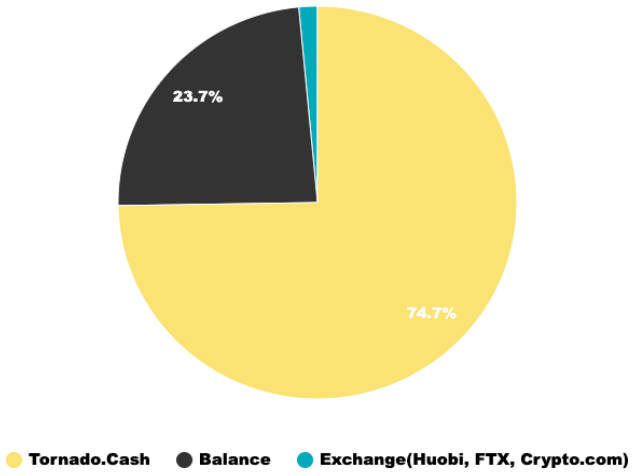
通过对上半年典型安全事件的整体分析，洗钱的主要流程发生在 ETH 链或 BTC 链，如果资金没有在这两条链上，黑客也会考虑将资金跨链到这两条链进一步变现。

通过对典型安全事件被盗资金的 ETH 和 BTC 流向进行分析，得到 ETH/BTC 资金流向图，能够初步评估出洗钱资金的态势。

(1) ETH 资金流向图



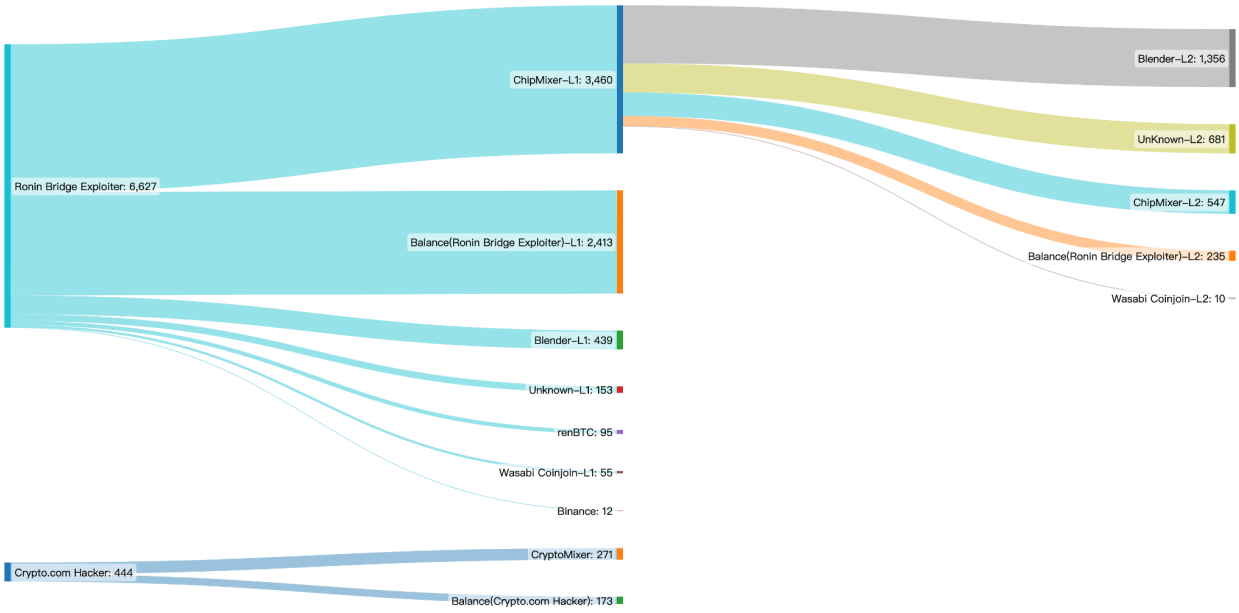
（典型安全事件 ETH 资金流向图）



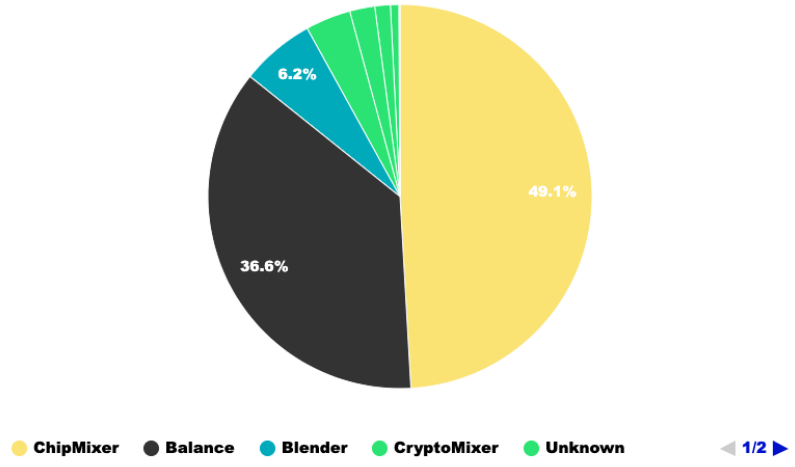
（典型安全事件 ETH 资金流向比例饼图）

根据典型安全事件 ETH **资金流向图，**74.6% **洗钱资金流向** Tornado.Cash，**资金量高达** 300,160 ETH；23.7% **洗钱资金保留在黑客地址，暂未进一步转移，资金量为** 95,570 ETH；1.5% **洗钱资金流向交易平台，资金量为** 6,250 ETH。

(2) BTC 资金洗钱图



（典型安全事件 BTC 资金流向图）



（典型安全事件 BTC 资金流向比例饼图）

根据典型安全事件 BTC 资金流向图，48.9% 洗钱资金流向 ChipMixer，资金量高达 3,460 BTC；36.5% 洗钱资金保留在黑客地址，暂未进一步转移，资金量为 2,586 BTC；6.2% 洗钱资金流向

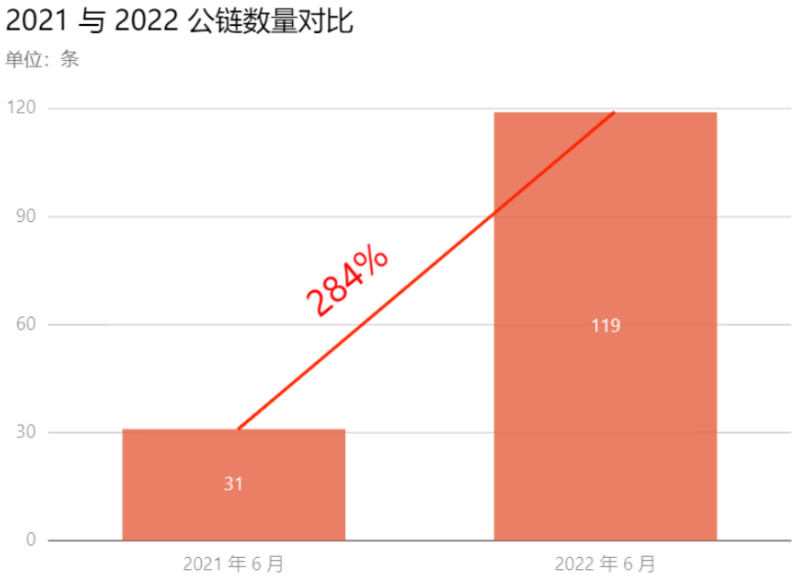
Blender，3.8% 洗钱资金流向 CryptoMixer，2.1% 洗钱资金流向未知主体，1.3% 洗钱资金流向 renBTC，0.7% 洗钱资金流向 Wasabi Coinjoin，0.1% 洗钱资金流向 Binance 交易平台。

二、区块链安全现状

2.1 区块链生态安全概览

2.1.1 公链赛道

作为区块链行业的基础设施，公链承载了人们对于区块链作为 Web3 底层网络的期望。随着一代又一代公链的崛起，NFT、DeFi、GameFi、元宇宙等生态热潮也相继迎来爆发，同时这些项目也促进了公链的发展与价值提升，使多链世界从理想走向了现实。据 Footprint Analytics 的数据，截至 6 月累计已收录的公链数量有 119 条，对比 2021 年 6 月收录的 31 条，同比增长约 284%。

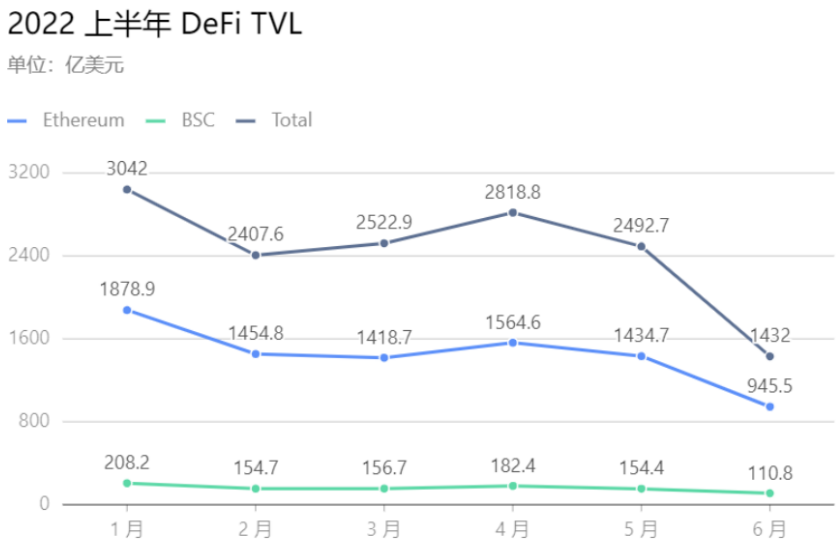


（2021 与 2022 年 6 月公链数量对比）

2.1.1.1 DeFi

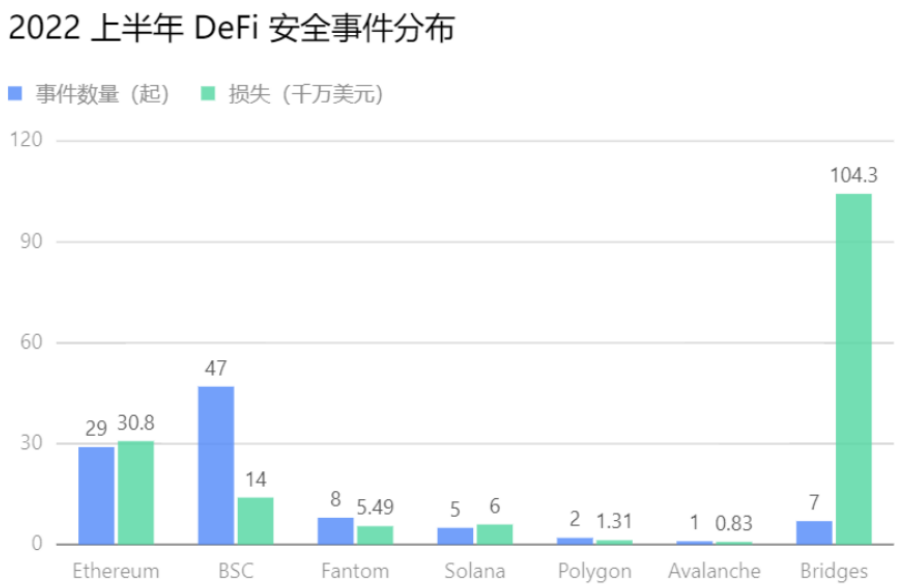
据 DeFi Llama 数据显示，6 月 30 日 DeFi 总锁仓价值为 1432 亿美元，其中ETH 链以 945.5 亿美元的 TVL（Total Value Locked）占据了资金沉淀的半壁江山，其次是 BSC 链的 110.8 亿美元。

2021 年以来，许多新兴公链如 Solana、Avalanche 等通过拥抱 DeFi 快速发展链上生态，也吸引了大量用户和资金沉淀。6 月 30 日 Solana TVL 为 26.4 亿美元，同比增长 77%；Avalanche TVL 为 55.4 亿美元，同比增长 96%。



（2022 上半年 DeFi TVL）

根据 SlowMist Hacked 统计，截至 6 月 30 日 DeFi 安全事件约 100 起，损失超 16.3 亿美元。其中在 BSC、ETH、Fantom、Solana、Polygon、Avalanche、跨链桥上发生的安全事件数量分别为 47 起、29 起、8 起、5 起、2 起、1 起、7 起，所造成损失分别为 1.4 亿美元、3.08 亿美元、5491 万美元、6383 万美元、1310 万美元、830 万美元、10.43 亿美元。



（2022 上半年 DeFi 安全事件分布）

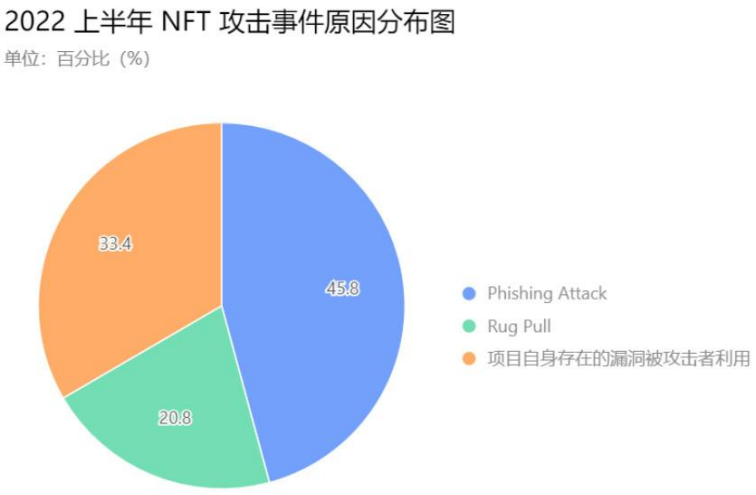
2.1.1.2 NFT

随着一批头部 NFT 项目的崛起和各路名人的参与，NFT 极速发展。根据Dune Analytics 的数据，OpenSea 的交易量在 1 月份达到上半年最高峰 2.84 亿美元，而随着加密货币市场的变化，OpenSea 在 6 月份的交易量只有 1558 万美元，下滑 94%。在 NFT 的热潮中，目前以太坊生态的 NFT 在市值和交易量依旧占据市场的主流，交易量超 90%。除了以太坊外，从近 30 天交易量和近 7 天交易量这些短期数据来看，Solana，Flow 等生态的 NFT 也正在快速发展，且表现亮眼，多链时代距离我们越来越近。



（2022 上半年 OpenSea 交易量变化图）

根据 SlowMist Hacked 不完全统计，截至 6 月 30 日 NFT 赛道安全事件约 48 起，损失超 6281 万美元。其中 33.4%（16 起）源于项目自身存在的漏洞被攻击者利用，20.8%（10 起）源于 Rug Pull，而钓鱼攻击占了大部分，占比为 45.8%（22 起），多数都是由于 Discord/Twitter 等媒体平台被黑后黑客发布钓鱼链接。

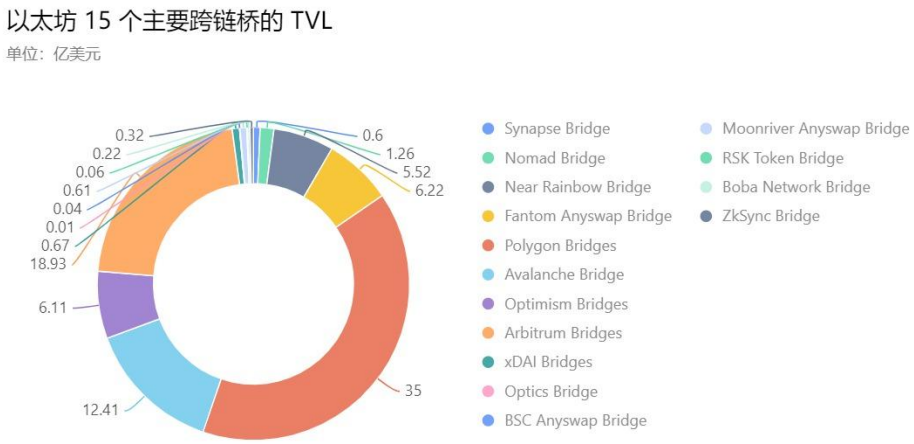


（2022 上半年 NFT 攻击事件原因分布图）

根据 TRM Labs 发布的 报告，在 5、6 两个月，由 TRM Labs 社区主导的诈骗报告平台 Chainabuse 收到了超过 100 份关于 Discord 黑客攻击的报告；自 5 月以来，NFT 社区损失约 2200 万美元；6 月，黑客在被黑的 Discord 中发布 NFT 相关的钓鱼攻击同比增加了 55%。

2.1.1.3 跨链桥

随着区块链的发展，目前已经进入一个以太坊为核心多链并存的局面，链与链之间的资产转移、智能合约的跨链交互已成为链上活动的日常，跨链桥作为区块链基础设施的地位越发凸显。根据 Dune Analytics 数据，截至 6 月 30 日以太坊中 15 个主要跨链桥的锁定总价值 (TVL) 约 83.9 亿美元。目前 TVL 最高的是 Polygon Bridges（35 亿美元），排名第二的是 Arbitrum Bridge（18.93 亿美元），随后是 Avalanche Bridge（12.41 亿美元）。



（以太坊 15 个主要跨链桥的 TVL）

由于流动资金量大，去中心化程度低，权限几乎都掌握在多签钱包中等特性，跨链桥也成了黑客眼中的“香饽饽”。根据 SlowMist Hacked 统计，截至 6 月 30 日跨链桥安全事件共 7 起，损失高达 10.43 亿美元，占比 DeFi 上半年总损失的 64%，占比上半年总损失的 53%。值得注意的是上半年损失金额上亿美元的事件 4 起中就有 3 起来自跨链桥。作为多链生态的重要基础设施，跨链桥一方面承担着巨量的资金流动，为用户带来了极大的便利，另一方面在安全性和去中心化水平上面临许多挑战，需要项目方提升安全、风控等能力。

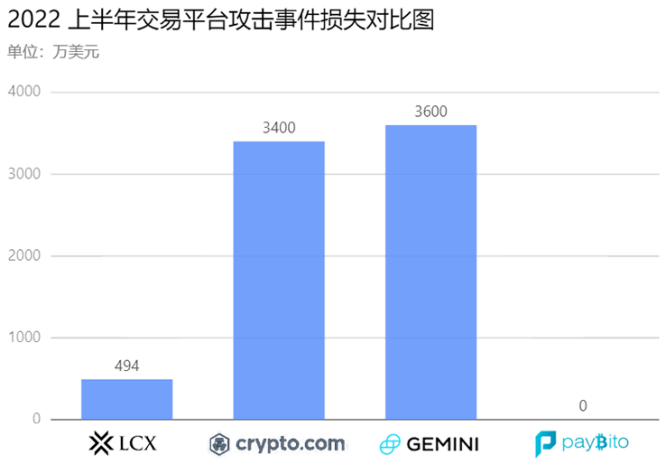


（2022 上半年跨链桥安全事件）

2.1.2 交易平台

加密货币行业一直处在监管旋涡中，首当其冲的就是加密货币交易平台。以全球交易量最大的平台 Binance 为例，自 2021 年来，Binance 已遭到数十个国家和地区的监管警告，包括欧洲、美洲、亚洲在内的多个地区。在全球强力监管信号下，Binance 陆续在西班牙、法国、阿布扎比、迪拜、意大利、巴林等国家或地区获得了监管许可并进行了注册，逐步推进其合规化进程。在上半年，全球共发生 4 起交易平台安全事件，损失超 7770 万美元，具体如下：

- 1 月 9 日，LCX 技术团队在 LCX 交易平台上检测到一个未经授权的访问，总共约 794 万美元的加密资产被盗。
- 1 月 17 日，Crypto.com 少数用户遭到未经授权提款，损失约 3400 万美元，包括 4,836.26 ETH、443.93 BTC 和约 66,200 美元的其他加密货币。
- 2 月 8 日，LockBit 勒索软件团伙称从加密货币交易平台 PayBito 窃取了大量客户数据。
- 2 月 12 日，来自美国南达科他州提供自主退休金帐户的 IRA Financial Trust 对加密交易平台 Gemini 提起诉讼，指控称由 Gemini 保管的属于客户退休账户的 3600 万美元加密资产被盗。



（2022 上半年交易平台攻击事件损失对比图）

建议各大交易平台健全内部管理与技术机制，通过引入安全审计机制、零信任机制、冷热资产安全解决方案等来加强对数字资产的安全保障。

2.1.3 其他

随着区块链风潮的骤起，其不可避免的也成为网络黑产眼中的肥肉。不法分子看中了加密货币的匿名性，使用非法手段获取了大量不义之财。区块链已成为网络黑产的新风口，呈现出越来越明显的组织化与专业化趋势，“勒索”、“欺诈”及“盗窃”已成为加密货币巨大安全威胁。

据 中国人民银行支付结算司数据，2021 年涉诈款项的支付方式中，利用加密货币进行支付仅次于银行转账，排名第二位，高达 7.5 亿美元；而 2020 年、2019 年仅为 1.3、0.3 亿美元，逐年大幅增长的趋势明显。值得关注的是，加密货币转账在“杀猪盘”诈骗中增长迅速。2021 年“杀猪盘”诈骗资金中 1.39 亿美元使用加密货币支付，是 2020 年的 5 倍、2019 年的 25 倍。

对于机构和企业来说，最好能够建立全面的网络安全防护系统，防护从各个层次入侵的网络安全威胁，并通过威胁感知体系快捷获取病毒木马、钓鱼诈骗、网络安全预警、漏洞报告在内的安全情报，一旦发生安全威胁能够及时进行处理。

而对于个人用户来说，遵守以下安全法则及原则，可以避免大部分风险：

两大安全法则：

- 零信任。简单来说就是保持怀疑，而且是始终保持怀疑。
- 持续验证。你要相信，你就必须有能力去验证你怀疑的点，并把这种能力养成习惯。

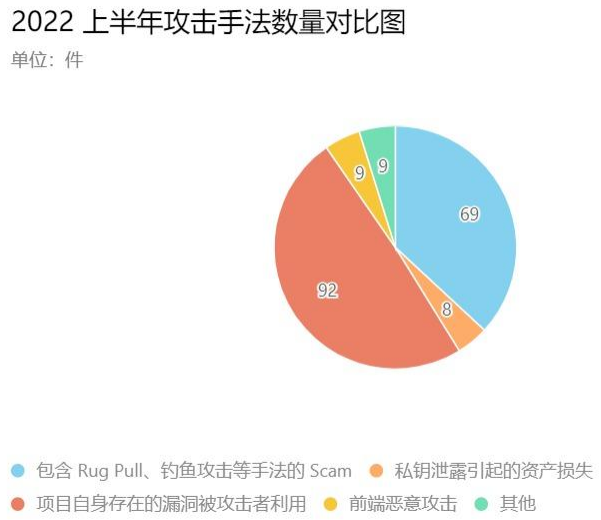
安全原则：

- 网络上的知识，凡事都参考至少两个来源的信息，彼此佐证，始终保持怀疑。
- 做好隔离，也就是鸡蛋不要放在一个篮子里。
- 对于存有重要资产的钱包，不做轻易更新，够用就好。
- 所见即所签。即你看到的内容就是你预期要签名的内容，当你签名发出去后，结果就应该是你预期的，绝不是事后拍断大腿的。
- 重视系统安全更新，有安全更新就立即行动。
- 不乱下程序。

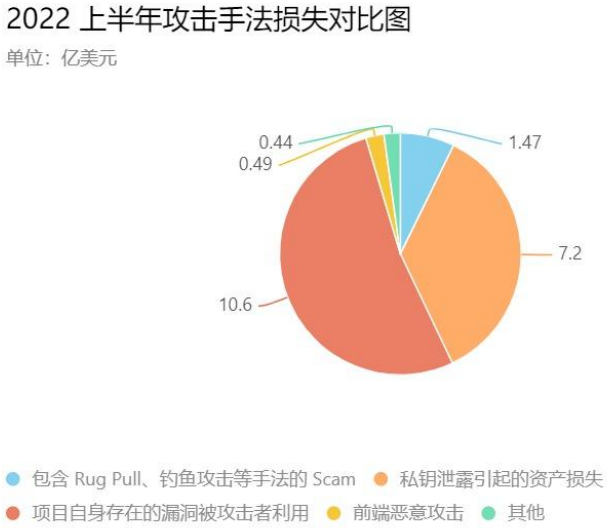
在此，十分推荐阅读并掌握《区块链黑暗森林自救手册》。

2.2 攻击手法概览

187 起安全事件中，攻击手法主要分为四类：由项目自身设计缺陷和各种合约漏洞引起的攻击；包含 Rug Pull、钓鱼攻击等手法的 Scam；由于私钥泄露引起的资产损失；前端恶意攻击，这四种主要攻击手法占比安全事件总数量的 95%。



（2022 上半年攻击手法数量对比图 ）



（2022 上半年攻击手法损失对比图 ）

上半年由项目自身设计缺陷和各种合约漏洞引起的攻击共 92 起，造成损失 10.6 亿美元，其中利用闪电贷引起的攻击有 19 起，造成损失 6133 万美元。因私钥被盗引起的资产损失发生率约为 4%，损失金额却达到 7.2 亿美元。

随着 Web3 的火热发展，针对用户和开发人员的攻击层出不穷，尤其是针对 Discord、Twitter 等媒体平台的钓鱼攻击，黑客通常会在获取到管理员或者账户权限后，伪装成管理员身份并发布钓鱼

链接。并且这些钓鱼网站的制作成本非常低，在对知名 NFT 项目进行 Copy 后，通过赠送、免费等字眼诱导用户授权，从而转移用户资产。而 Rug Pull 则是项目方主动作恶，上半年 Rug Pull 事件已达到 42 起，大部分发生在 BSC 链。

2.3 典型安全事件

此节选取了上半年部分典型安全事件，选取标准为损失较大，发生次数较多，影响范围较广及手法较新的事件。

2.3.1 Ronin Network 损失超 6.1 亿美元

3 月 29 日，Axie Infinity 侧链 Ronin Network 发布 社区预警，Ronin Network 出现安全漏洞，共 17.36 万枚 ETH 和 2550 万枚 USDC 被盗，损失超 6.1 亿美元。据官方发布的信息，攻击者使用被黑的私钥来伪造提款，仅通过两次交易就从 Ronin bridge 中抽走了资金。值得注意的是，黑客事件早在 3 月 23 日就发生了，但官方据称是在用户报告无法从 bridge 中提取 5k ETH 后才发现这次攻击。本次事件的损失甚至高于去年的 PolyNetwork 被黑事件，后者也窃取了超过 6 亿美元。事情背景可追溯到去年 11 月，当时 Sky Mavis 请求 Axie DAO 帮助分发免费交易。由于用户负载巨大，Axie DAO 将 Sky Mavis 列入白名单，允许 Sky Mavis 代表其签署各种交易，该过程于 12 月停止。但是，对白名单的访问权限并未被撤销，这就导致一旦攻击者获得了 Sky Mavis 系统的访问权限，就能够通过 gas-free RPC 从 Axie DAO 验证器进行签名。Sky Mavis 的 Ronin 链由九个验证节点组成，其中至少需要五个签名来识别存款或提款事件。攻击者通过 gas-free RPC 节点发现了一个后门，最终攻击者设法控制了五个私钥，其中包括 Sky Mavis 的四个 Ronin 验证器和一个由 Axie DAO 运行的第三方验证器。美国调查机构认为朝鲜黑客组织 LAZARUS GROUP 是此事件的幕后黑手。

2.3.2 Wormhole 损失超 3 亿美元

2 月 3 日，攻击者利用 Wormhole 网络中的签名验证漏洞在 Solana 上铸造了 12 万 WETH，价值超 3.26 亿美元。Wormhole 发布针对该事件的报告 中指出，此次事件中 Wormhole 的漏洞具体是 Solana 端核心 Wormhole 合约的签名验证代码存在错误，允许攻击者伪造来自"监护人"的消息来铸造 Wormhole 的 WETH。本次事件是目前针对 Solana 的黑客攻击中造成的最大损失规模事件。

2.3.3 Beanstalk Farms 遭闪电贷和提案攻击

4 月 17 日，基于以太坊的算法稳定币项目 Beanstalk Farms 遭 攻击，损失约为 1.82 亿美元。本次攻击的主要原因在于提案的投票与执行两阶段间无时间间隔，导致攻击者在完成投票后未经社区审核可以直接执行恶意提案。有趣的是，攻击者将其中 25 万美元捐赠给了一个用于为乌克兰政府筹集捐款的地址。

2.3.4 Harmony 损失超 1 亿美元

6 月 24 日，Harmony Horizon bridge 遭到黑客 攻击 。经慢雾 MistTrack 分析，攻击者获利超 1 亿美元，包括 11 种 ERC20 代币、13,100 ETH、5,000 BNB 以及 640,000 BUSD。26 日 Harmony 创始人 Stephen Tse 在 Twitter 上表示，Horizon 被攻击并非因为智能合约漏洞，而是由私钥泄露导致。虽然 Harmony 对私钥进行了加密存储，但攻击者还是解密了其中部分私钥并签名了一些未经授权的交易。

2.3.5 Pokemoney 发生 Rug Pull

BSC 上 NFT 项目 Pokemoney 发生 Rug Pull，约 1.18 万枚 BNB（约350 万美元）被提取转移。PokeMoney 背后的团队声称价格暴跌是由于神秘的黑客攻击。虽然没有证据证明黑客入侵，但该项目团队坚决支持这个说法。他们在 Telegram 上声称，由于某种原因，他们无法访问该项目的 Twitter 帐户，因此无法告知社区有关黑客行为的解释。

2.3.6 Crypto.com 部分账户遭黑客攻击

据 Crypto.com 调查报告，“2022 年 1 月 17 日，Crypto.com 获悉少数用户在其账户上未经授权提取了加密货币。Crypto.com 立即暂停所有代币的提款以启动调查，并全天候工作以解决该问题。没有客户遭受资金损失。在大多数情况下，我们阻止了未经授权的提款，在所有其他情况下，客户都得到了全额报销。该事件影响了 483 名 Crypto.com 用户。 未经授权的提款总额为 4,836.26 ETH、443.93 BTC 和约 66,200 美元的其他货币。”

2.3.7 Uniswap 空投钓鱼攻击

7 月 12 日，Binance 创始人 CZ 发推 表示，通过威胁情报在 ETH 区块链上检测到 Uniswap V3 潜在漏洞。几个小时后，多名 Twitter 用户发布消息称，此次黑客攻击中转移资金的交易并无异常，并表示这是一次网络钓鱼攻击，超过 70,000 个连接到 Uniswap 的地址被空投代币，空投代币将用户链接到一个类似于真实 Uniswap 网站的钓鱼网站。用户被诱骗授权合约，从而允许攻击者控

制其钱包，盗取其加密货币和 NFT。其中一个钱包损失了超过 650 万美元，另一个钱包损失了价值约 168 万美元的加密货币。

2.3.8 OpenSea 多名用户遭邮件钓鱼

2 月 20 日，全球最大的加密数字藏品市场 OpenSea 遭到 攻击 。根据 OpenSea 官方的推文，黑客在 OpenSea 合约升级的同时，向所有用户邮箱发送了钓鱼邮件，很多用户误以为是官方邮件，对钱包进行了授权，导致钱包被盗。

2.3.9 ApeCoin 空投闪电贷套利

3 月 17 日，根据 Twitter 用户 Will Sheehan 的 报告，套利机器人通过闪电贷薅羊毛，拿到 6w 多 ApeCoin（每个价值 8 美元）。分析发现这和 ApeCoin 的空投机制存在漏洞有关。具体来说，ApeCoin 能否空投取决于某一个用户是否持有 BYAC NFT 的瞬时状态，而攻击者可以通过借入闪电贷来操纵瞬时状态。攻击者首先通过闪电贷借入 BYAC Token，接着 redeem 获得 BYAC NFT，然后使用这些 NFT 来 Claim 空投的 APE，最后将 BYAC NFT mint 获得的 BYAC Token 用来返还闪电贷。

2.3.10 BAYC 官方 Discord 遭攻击

6 月 5 日，BAYC 在官方 推特 表示，其 Discord 服务器被短暂攻击，价值约 200ETH 的 NFT 被盗。此次攻击是由于社区管理员的帐户遭到入侵，黑客冒充管理员身份发布了一个指向钓鱼网站的链接。

2.3.11 FEG 遭两次闪电贷攻击

5 月 16 日，多链 DeFi 协议 FEG 遭到闪电贷 攻击，攻击者窃取 144 ETH 和 3,280 BNB，损失约 130 万美元。5 月 17 日，FEG 再次受到攻击，攻击者窃取 291 ETH 和 4,343 BNB，损失约 190 万美元，其中 BSC 链 130 万美元，ETH 链 60 万美元。两次攻击类似，主要原因是未验证 swapToSwap 函数中 path 地址参数，导致攻击者可以任意传入恶意 path 地址，使得 FEGexPRO 合约将自身代币授权给攻击者。

2.3.12 Optimism 因合约漏洞损失 2000 万枚 OP

6 月 9 日，Optimism 与 Wintermute 双双发布 公告，向社区披露了一起 2000 万 OP 代币丢失的事件。在 OP 代币发布之时，Optimism 委托 Wintermute 来为 OP 在二级市场上提供流动性服务，

Optimism 将向 Wintermute 提供 2000 万枚 OP 代币。为了接收这笔代币，Wintermute 给了 Optimism 一个多签地址，在 Optimism 测试发送了两笔交易且 Wintermute 确认无误后，Optimism 将 2000 万 OP 转移到了该地址。在 Optimism 转完币之后，Wintermute 却发现自己没办法控制这些代币，因为他们所提供的多签地址暂时只部署在了以太坊主网上，尚未向 Optimism 网络部署。为了控制这些代币，Wintermute 立即启动了补救操作。但已有攻击者察觉到了这一漏洞，并抢在 Wintermute 之前将该多签地址部署到了 Optimism 网络上，成功控制了这 2000 万代币。目前 Optimism 黑客已归还 1700 万枚 OP 代币，并向 Vitalik 地址转入 100 万枚 OP，而 Vitalik 已将此资金归还。

2.3.13 MM.finance 遭 DNS 劫持攻击

5 月 4 日，据官方 发文 称，MM.finance 网站遭到 DNS 攻击，攻击者设法将恶意合约地址注入前端代码。攻击者利用 DNS 漏洞修改托管文件中的路由器合约地址，价值 200 万美元以上的加密货币资产被盗，并通过跨链桥转移到 ETH 链，随后通过 Tornado.Cash 洗钱。

2.3.14 KLAYswap 遭到恶意前端攻击

2 月 3 日，韩国 DeFi 项目 KLAYswap 发布 公告 称遭黑客攻击，损失约 22 亿韩元，约合 183 万美元。公告中称黑客通过 BGP 劫持篡改 KLAYswap 前端的第三方 JS 链接，导致用户访问 KLAYswap 页面时被投毒，然后授权资产给黑客钱包地址，最终导致用户资产被盗，期间共有 325 个钱包发生 407 笔异常交易。

2.3.15 Terra 生态崩溃

5 月 9 日，Terra 生态算法稳定币 UST 严重脱钩、LUNA 近乎归零，数百亿美元市值一夕蒸发。Luna Foundation Guard (LFG) 使用了价值约 35 亿美元的比特币来维持 UST 的价值。但并没有起作用。最终，在 5 月 12 日，Terra 停止运行。Terra 的崩溃导致了 600 亿美元的损失，造成了比特币价格的抛售压力效应，并在整个加密资产中产生了恐惧情绪，加剧了行业正在经历的熊市。

三、典型安全事件反洗钱分析

关于典型安全事件反洗钱分析，我们将主要讨论以下的内容：

- 提出一种针对混币器（Tornado.Cash 和 ChipMixer）资金转出的分析方法
- 应用反洗钱分析方法对典型安全事件进行分析

3.1 典型安全事件损失概览

根据上文，摘取了上半年部分典型安全事件进行反洗钱分析。

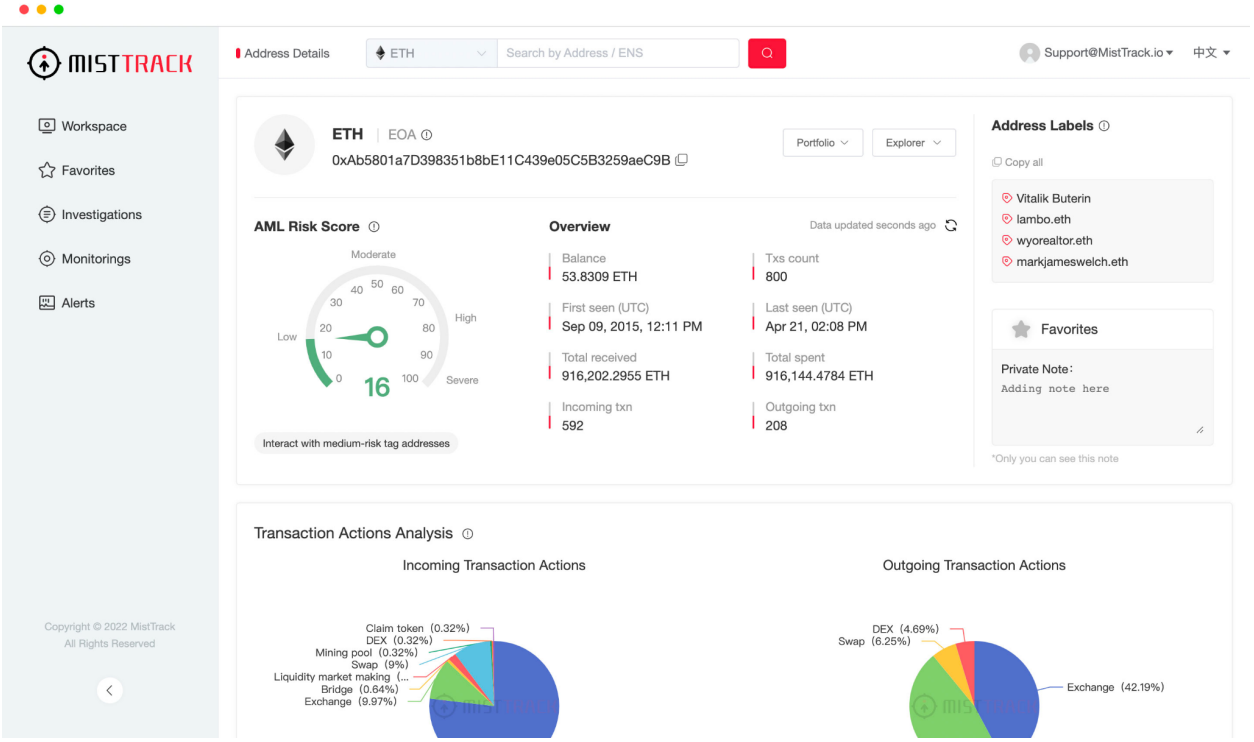
事件	被盗时间	损失统计
Ronin Network	3 月 23 日	173,600 ETH、25,500,000 USDC
Wormhole	2 月 2 日	120,000 WETH
Beanstalk	4 月 17 日	24,830 ETH、250,000 USDC 代币和 36,390,000 BEAN 代币
Harmony	6 月 23 日	ETH 链：13,100 ETH、41,200,000 USDC、592 WBTC、9,981,000 USDT、6,070,000 DAI、5,530,000 BUSD、84,620,000 AAG、110,000 FXS、415,000 SUSHI、990 AAVE、43 WETH 和 5,620,000 FRAX BSC 链：5,000 BNB 和 640,000 BUSD
Crypto.com	1 月 17 日	ETH 链：4,836.25 ETH BTC 链：443.93 BTC
Uniswap Phishing	7 月 11 日	3,278.84 ETH 和 240.42 WBTC
ApeCoin 空投闪电贷套利	3 月 17 日	60,564 APE
BAYC 官方 Discord 遭攻击	6 月 4 日	价值超过 145 个 ETH（25.6 万美元）的 NFTs
FEGToken	5 月 15 日、5 月 16 日	443.86 ETH 和 7,626.49 BNB
Optimism	5 月 27 日	20,000,000 OP 代币（17,000,000 OP 已归还）

MM.finance	5 月 4 日	2,000,000 美元

3.2 工具及方法

在正式开始反洗钱分析之前，我们首先要有一个高效的工具和一套有效应对复杂洗钱情况的分析方法。

3.2.1 基础工具 - MistTrack



（MistTrack 反洗钱追踪系统示例图 ）

MistTrack 反洗钱追踪系统 是一套由慢雾科技创建的专注于打击加密货币洗钱活动的 SaaS 系 统，具有资金风险评分模块、交易行为分析模块、资金溯源追踪模块、资金监控模块等核心功能。

- **AML Risk Score**

MistTrack 反洗钱追踪系统主要从地址所属实体、地址历史交易活动、慢雾恶意钱包地址库三方面为其计算 AML 风险评分。当地址所属实体为高风险主体（如混币平台）或地址与已知的风险主体存在资金来往时，系统会将该地址标记为风险地址。同时，结合慢雾恶意钱包地址库中的恶意地址数据集，对已核实的勒索、盗币、钓鱼欺诈等非法行为的涉案地址进行风险标记。

- **Address Labels**

MistTrack 反洗钱追踪系统积累了超 2 亿个钱包地址标签，地址标签主要包含 3 个分类：

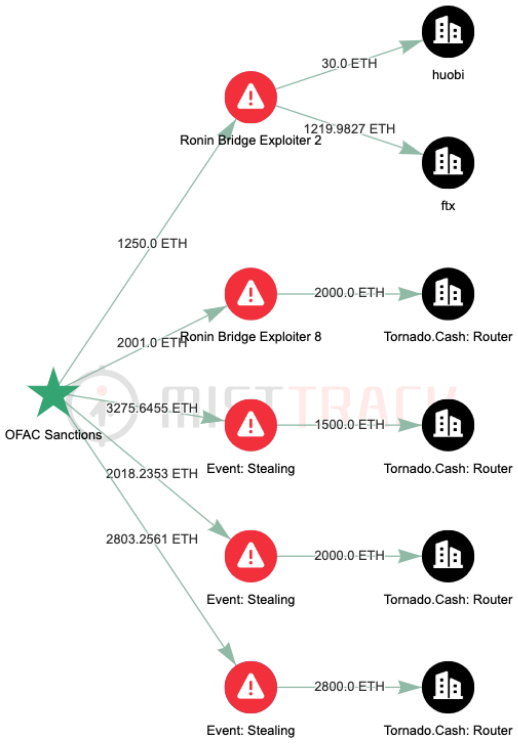
(1) 它归属于什么实体，如 Coinbase、Binance

(2) 它的链上行为特征，如 DeFi 鲸鱼、MEV Bot 以及 ENS

(3) 一些链下情报数据，如曾使用过 imToken/MetaMask 钱包

- **Investigations**

追踪和识别钱包地址上的加密资产流向，实时监控资金转移，将链上和链下信息整合到一个面板中，为司法取证提供强有力的技术支持。



（MistTrack 追踪分析示例图 ）

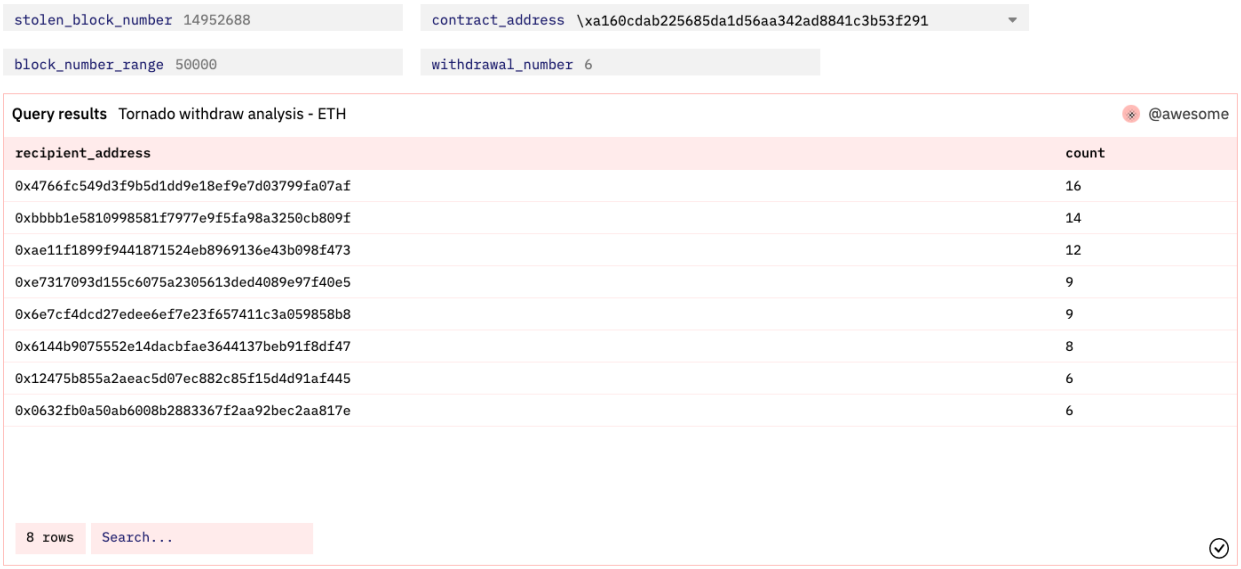
通过标记 1 千多个地址实体、2 亿多个地址标签，10 万多个威胁情报地址，以及超过 9000 万个与恶意活动相关的地址，MistTrack 为反洗钱分析和研究提供了全面的情报数据帮助。通过对任意钱包地址进行交易特征分析、行为画像以及追踪调查，MistTrack 在反洗钱分析评估工作中起到至关重要的作用。

3.2.2 拓展方法 - 数据分析

MistTrack 可以满足常见的反洗钱分析场景，而遇到复杂特殊的情况就需要其他的方法辅助分析。从区块链反洗钱资金态势中我们可以看到很多被黑事件发生后，在 ETH/BSC 链上的资金都不约而同的流向了一片灰暗之地——Tornado.Cash，Tornado.Cash 已成为 ETH/BSC 链上反洗钱的主战场。

新的洗钱手法需要新的分析方法，对 Tornado.Cash 转出分析的需求变得越来越普遍，此处我们将提出一个针对 Tornado.Cash 资金转出的分析方法。

- 记录目前已知的信息，已知信息包括转入 Tornado.Cash 总数，第一笔 Tornado.Cash 存款时间，第一笔 Tornado.Cash 存款的区块高度。
- 将参数填入我们准备的 分析面板 。
- 得到初步的 Tornado.Cash 提款数据结果，再使用特征分类的方式对数据结果做进一步筛选。
- 筛选后的结果是一批疑似黑客转出的结果集，取概率最高的结果集并对它进行验证。
- Tornado.Cash 转出分析结论。



（Dune Dashboard - Tornado.Cash 转出分析）

通过这个 Tornado.Cash 资金转出的分析方法，我们已成功分析出 Ronin Network 等多个安全事件从 Tornado.Cash 转出后的资金详情。

显而易见，这个 Tornado.Cash 资金转出的分析方法同样存在局限性：
转入 Tornado.Cash 的数量分类也是一个匿名集，资金量越大相应的匿名集数量越少，资金量越小则相反。所以对于资金量小的分析难度更大。

而在 BTC 链上，通过区块链反洗钱资金态势我们可以看到 ChipMixer 和 Blender 是黑客的常用洗钱平台。Blender 目前已被美国财政部制裁，站点已不可用，这里不再做进一步的探讨。

ChipMixer 流入洗钱资金量巨大，我们同样需要提出一个针对 ChipMixer 资金转出的分析方法。

- 识别 ChipMixer 的提款特征。

输入地址类型	输出地址类型	输入数额特征	版本	锁定时间
bech32(bc1q...)	bech32(bc1q...)	所有的输入数额都满足 Chips(即 0.001 * 2 的 n 次方，n < 14)的要求	2	区块高度 - 1/ 区块高度 - 2/ 区块高度 - 3

- 根据上述提款特征对相应时间段的结构化区块数据进行扫描和筛选，得到这个时间段内 ChipMixer 的提款记录。
- 对提款记录数据归类结果集，取概率最高的结果集并对它进行验证。
- ChipMixer 转出分析结论。

3.3 反洗钱分析详述

3.3.1 Ronin Network

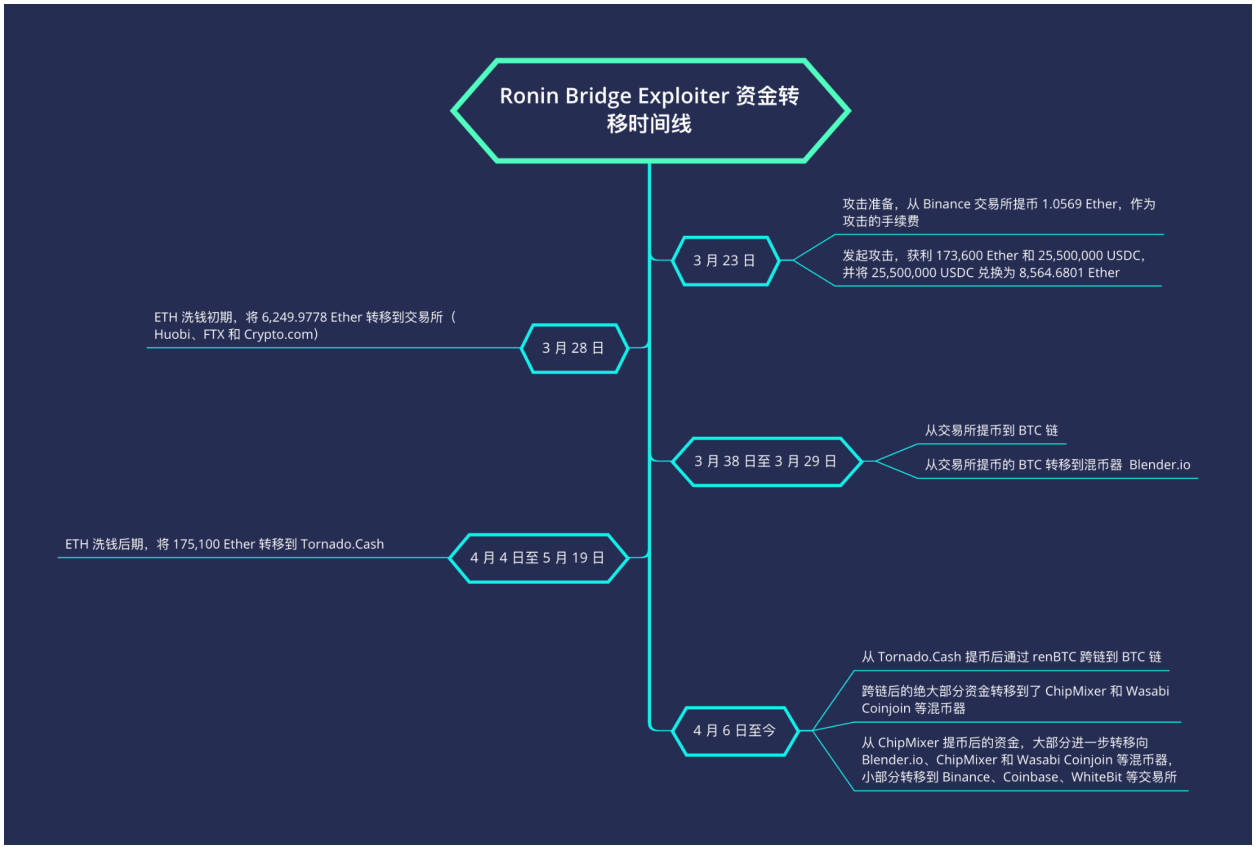
黑客地址：0x098B716B8Aaf21512996dC57EB0615e2383E2f96（ETH 链）

被盗时间：3 月 23 日

损失统计：173,600 ETH、25,500,000 USDC

攻击手续费来源：SimpleSwap

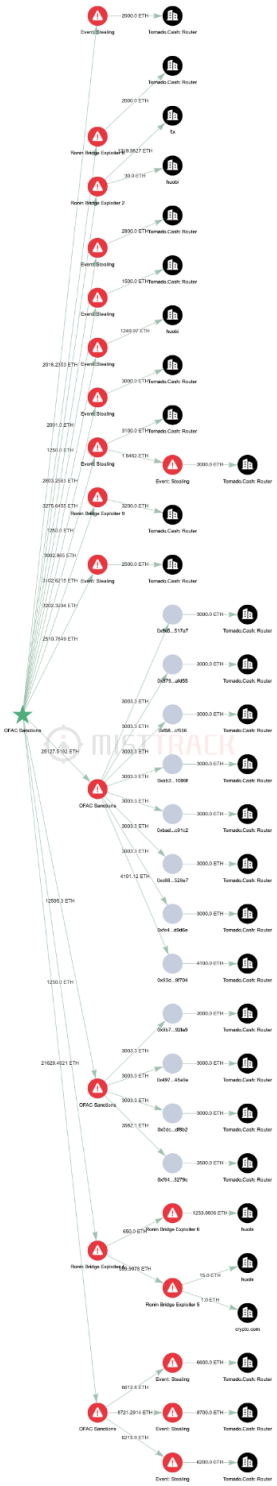
资金转移：



（Ronin Bridge Exploiter 资金转移时间线）

ETH 资金转移

黑客将攻击获利的 25,500,000 USDC **兑换为了** 8,562.6801 ETH，**所以黑客需要洗币的总额为** 182,163.737 ETH（Binance **提款** 1.0569 ETH + **攻击所得** 173,600 ETH + **攻击兑换** USDC **所得** 8,562.6801 ETH）。



（Ronin Bridge Exploiter 资金转移图）

黑客获利资金流向主体详情如下表：

主体	流向资金
Tornado.Cash	175,100 ETH
Huobi	5,028.9951 ETH
FTX	1,219.9827 ETH
Crypto.com	1 ETH
Balance	667.3916 ETH

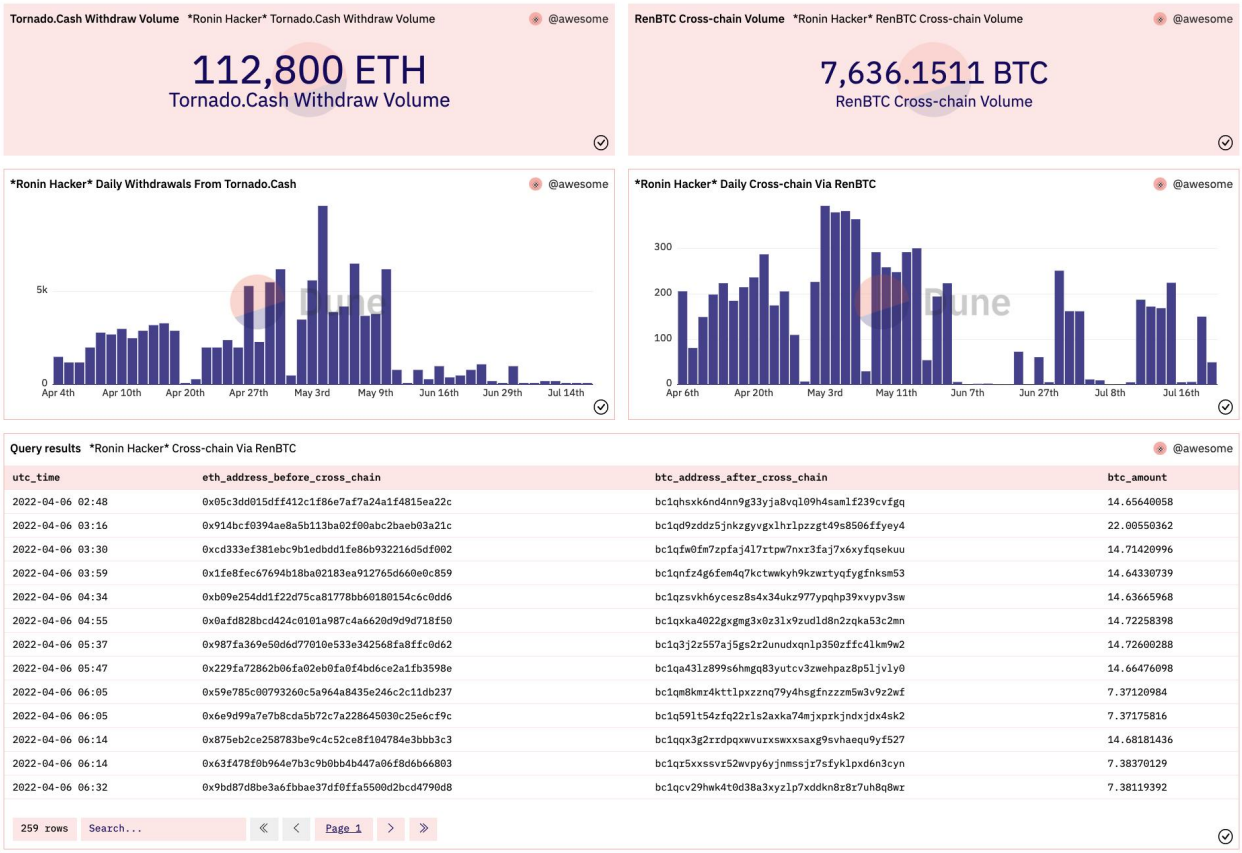
注：其他未做统计的流向资金为洗币过程损失。

Tornado.Cash 资金转移

黑客总计转入 Tornado.Cash 175,100 ETH，经过分析，我们得出 Ronin 黑客从 Tornado.Cash 提款符合下列特征：

从 Tornado.Cash 转出后直接或转移一层后使用 1inch 或 Uniswap 兑换为 renBTC，通过 renBTC 跨链到 BTC 链。

通过 Dune Analytics，我们将符合上述特征的 Tornado.Cash 提款和跨链到 BTC 链的数据筛选出来，并进行有效的 可视化展示，如下图：



（Ronin 黑客从 Tornado.Cash 转出后通过 renBTC 跨链数据）

根据上面的分析图，得到 Tornado.Cash 转出资金情况如下表：

流向	流向资金
通过 renBTC 跨链到 BTC 链	112,800 ETH
在 Tornado.Cash 中的余额	62,300 ETH

注：数据有效时间截止于 7 月 20 日。

BTC 资金转移

根据对 Tornado.Cash 资金转移的分析，我们得到符合特征的共计 8,075.9329 BTC 的资金跨链到 BTC 链。其中的 6,191.2542 BTC 经过分析确认与 Ronin 黑客相关，再加上从 Huobi 和 FTX 提款的 439.7818 BTC，确认共计 6,631.036 BTC 为 Ronin 黑客所属资金。此部分资金的进一步转移情况如下表：

主体	流向资金
ChipMixer	3460.6845 BTC
Blender	439.7818 BTC
Wasabi Coinjoin	55.1448 BTC
renBTC	95.6871 BTC
Coinbase	0.5632 BTC
ChangeHero	0.488 BTC
Binance	12.0973 BTC
Wirex	0.0399 BTC
Kuna	0.0384 BTC
Any.Cash	0.0676 BTC
Unknown	153.0143 BTC
Balance	2413.4292 BTC
合计	6631.036 BTC

注：0.1 BTC 以下转移额不做统计。

ChipMixer 资金转移

根据 BTC 资金转移可以看到 3460.6845 BTC 转移到了 ChipMixer，通过对 BTC 链上数据监控以及对 ChipMixer 的提款数据进行分析，识别出 Ronin 黑客从 ChipMixer 共计提款 2,871.03 BTC。此部分资金的进一步转移情况如下表：

主体	流向资金
Blender	1356.0 BTC

Wasabi Coinjoin	9.8365 BTC
ChipMixer	547.7938 BTC
UnKnown	681.4247 BTC
Balance	235.4739 BTC

注:0.1 BTC 以下转移额不做统计。

3.3.2 Wormhole

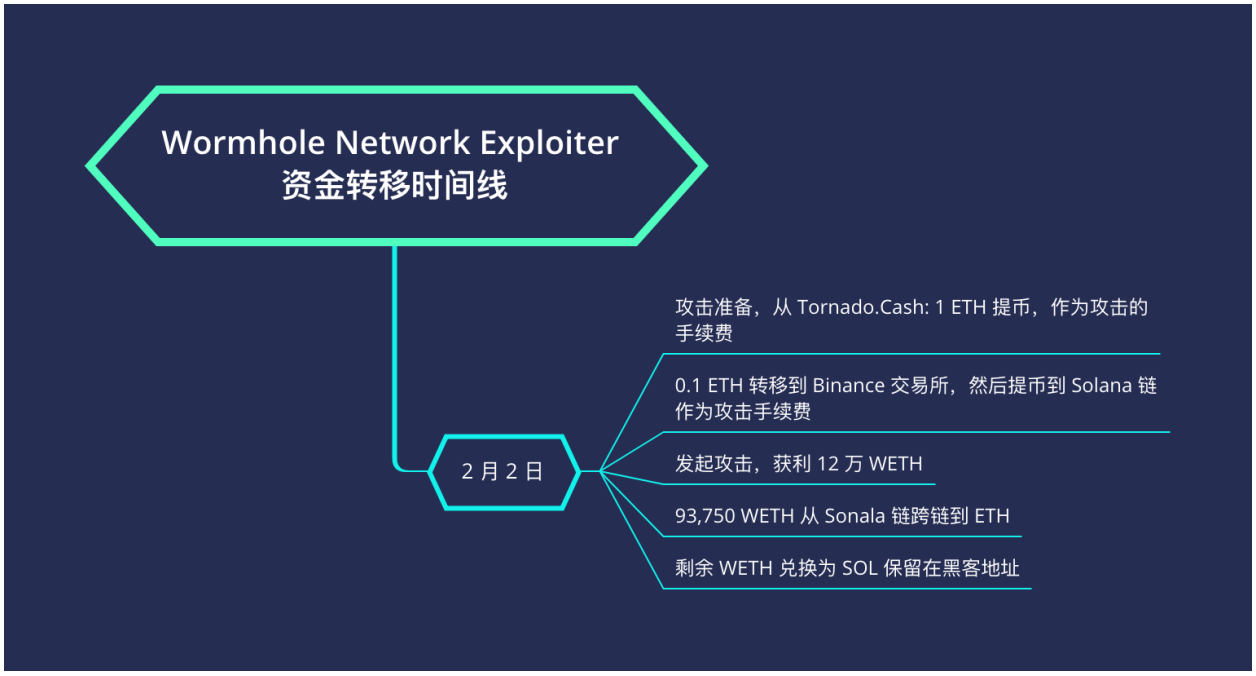
黑客地址: CxegPrfn2ge5dNiQberUrQJkHCcimeR4VXkeawcFBBka (Solana)

被盗时间：2 月 2 日

损失统计：120,000 WETH

攻击手续费来源：Tornado.Cash

资金转移：



（Wormhole Network Exploiter 资金转移时间线）

WETH 资金转移

流向	流向资金
跨链到 ETH 链	93,750 WETH
兑换为 SOL	26,250 WETH

黑客地址余额

地址	余额
CxegPrfn2ge5dNiQberUrQJkHCcimeR4VXkeawcFBBka	432,661.15 SOL
0x629e7da20197a5429d30da36e77d06cdf796b71a	93,750.623 ETH

3.3.3 Beanstalk

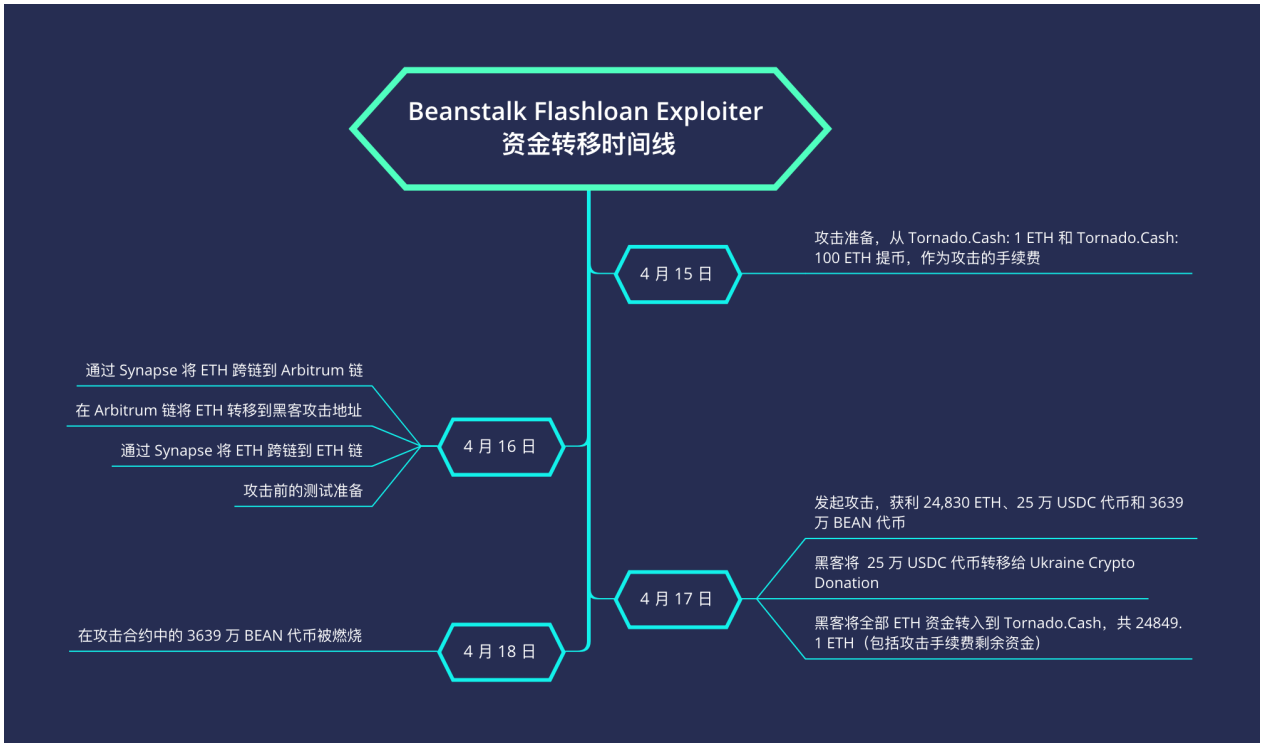
黑客地址:0x1c5dCdd006EA78a7E4783f9e6021C32935a10fb4(ETH 链)

被盗时间：4 月 17 日

损失统计：24,830 ETH、250,000 USDC 代币和 36,390,000 BEAN 代币

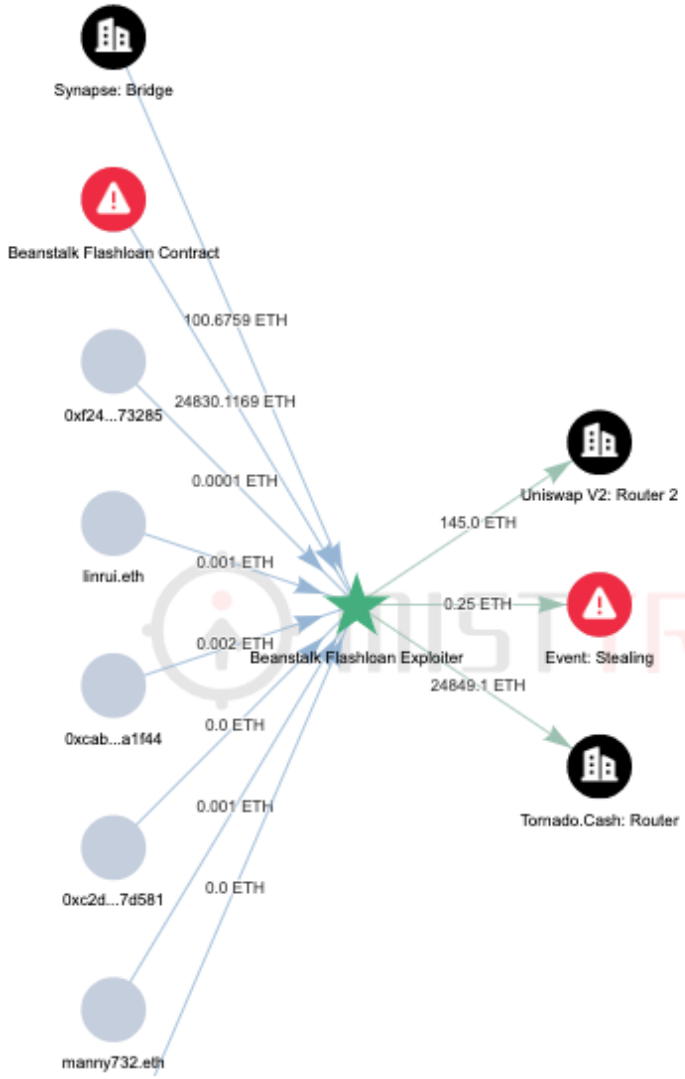
攻击手续费来源：Tornado.Cash

资金转移：



（Beanstalk Flashloan Exploiter 资金转移时间线）

ETH 资金转移



（Beanstalk Flashloan Exploiter ETH 资金转移图）

ETH 的资金转移如下表：

流向	流向资金
Tornado.Cash	24849.1 ETH

注：转移资金中包括攻击手续费剩余资金。

3.3.4 Harmony

黑客地址：

0x0d043128146654C7683Fbf30ac98D7B2285DeD00（ETH 链）

0x0d043128146654C7683Fbf30ac98D7B2285DeD00（BSC 链）

被盗时间：6 月 23 日

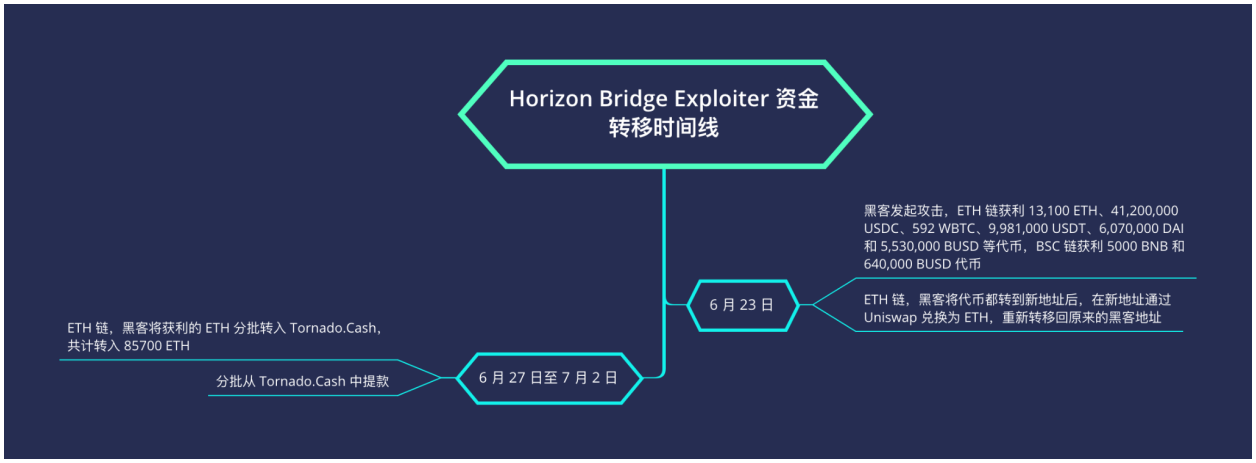
损失统计：

（ETH 链）13,100 ETH、41,200,000 USDC、592 WBTC、9,981,000 USDT、6,070,000 DAI、5,530,000 BUSD、84,620,000 AAG、110,000 FXS、415,000 SUSHI、990 AAVE、43 WETH 和 5,620,000 FRAX

（BSC 链）5,000 BNB 和 640,000 BUSD

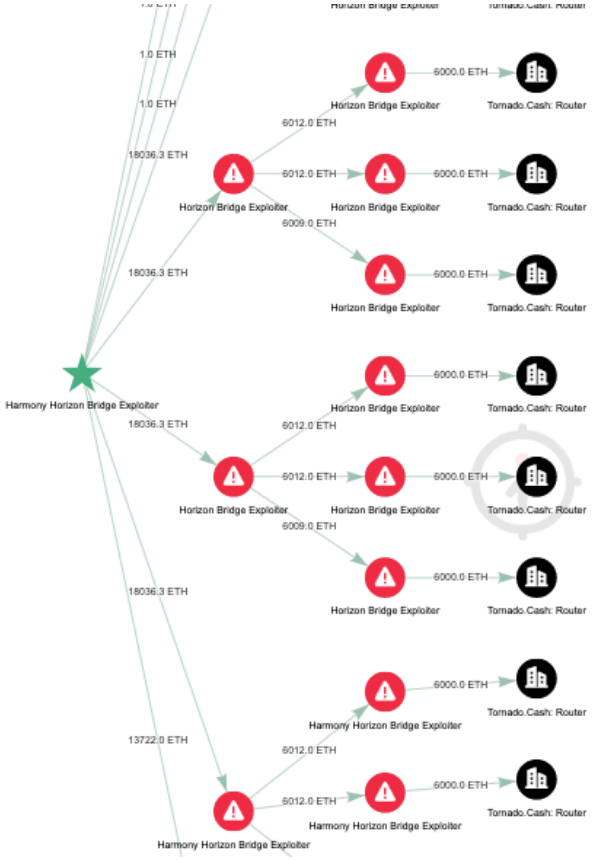
攻击手续费来源：无

资金转移：



（Horizon Bridge Exploiter 资金转移时间线）

ETH 资金转移



（Horizon Bridge Exploiter ETH 资金转移图）

ETH 资金转移表：

流向	流向资金
Tornado.Cash	85,700 ETH
Balance	201.2094 ETH

Tornado.Cash 资金转移

黑客总计转入 85,700 ETH 到 Tornado.Cash，经过分析，我们得出 Harmony 黑客的 Tornado.Cash 提款符合下列特征：

- 从 Tornado.Cash 的分批提款，每个提款地址的提款次数相对固定，主要提款次数是 5 和 6，即提款 5 * 100 ETH 或 6 * 100 ETH 到提款地址。
- 从 Tornado.Cash 提款后，长达一个月未发生进一步转移。

根据上述的 Tornado.Cash 提款特征，共计发现了黑客 83,300 ETH 的提款，从 Tornado.Cash 转出资金情况如下表：

流向	流向资金
Balance	83,300 ETH

3.3.5 Crypto.com

黑客地址：

0x6e1218c55f1aCb588Fc5E55B721f1183D7D29D3d（ETH 链）

bc1qk8wlwypvvr6v5lmsngg5a248k2a9cgrsrw5jsq（BTC 链）

bc1q83c9e7s8925hhy9dzqpdyyfctgwaspj3wdrhqr（BTC 链）

bc1qk7e2k8s252789cggr5xy67m6jvc0jsqpdjfw9d（BTC 链）

bc1qnzn9wmt40qwuhd7zmqvmvd0c3zazv59ljplrnr（BTC 链）

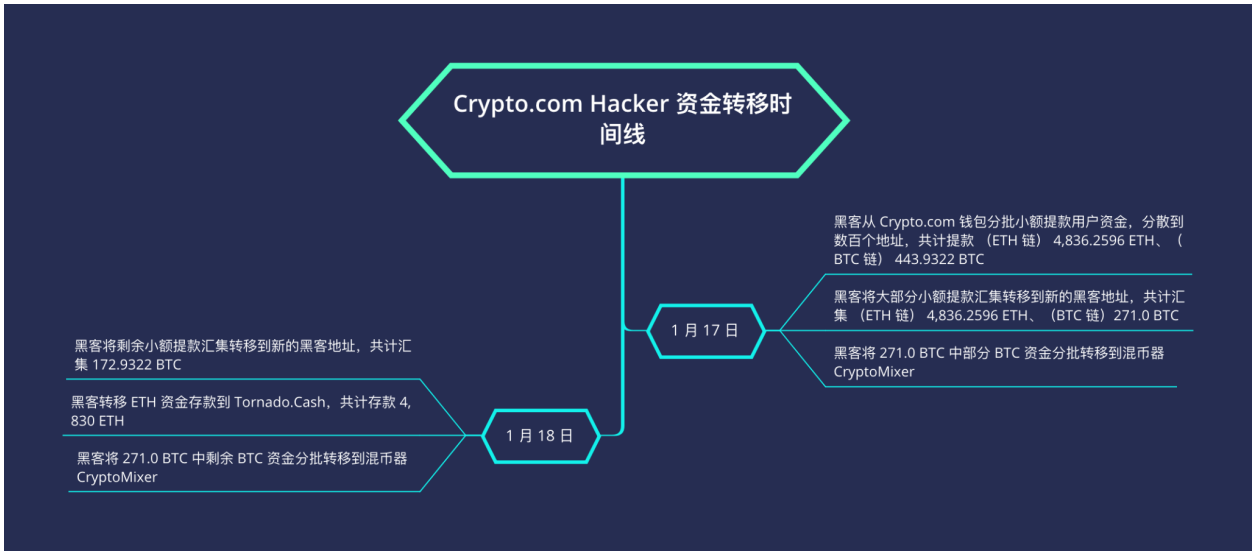
bc1qy7hf94vv20jqez2fk8xyxuv0h0u8r0kh8cau46（BTC 链）

被盗时间：1 月 17 日、1 月 18 日

损失统计：（ETH 链）4,836.2596 ETH、（BTC 链）443.9322 BTC

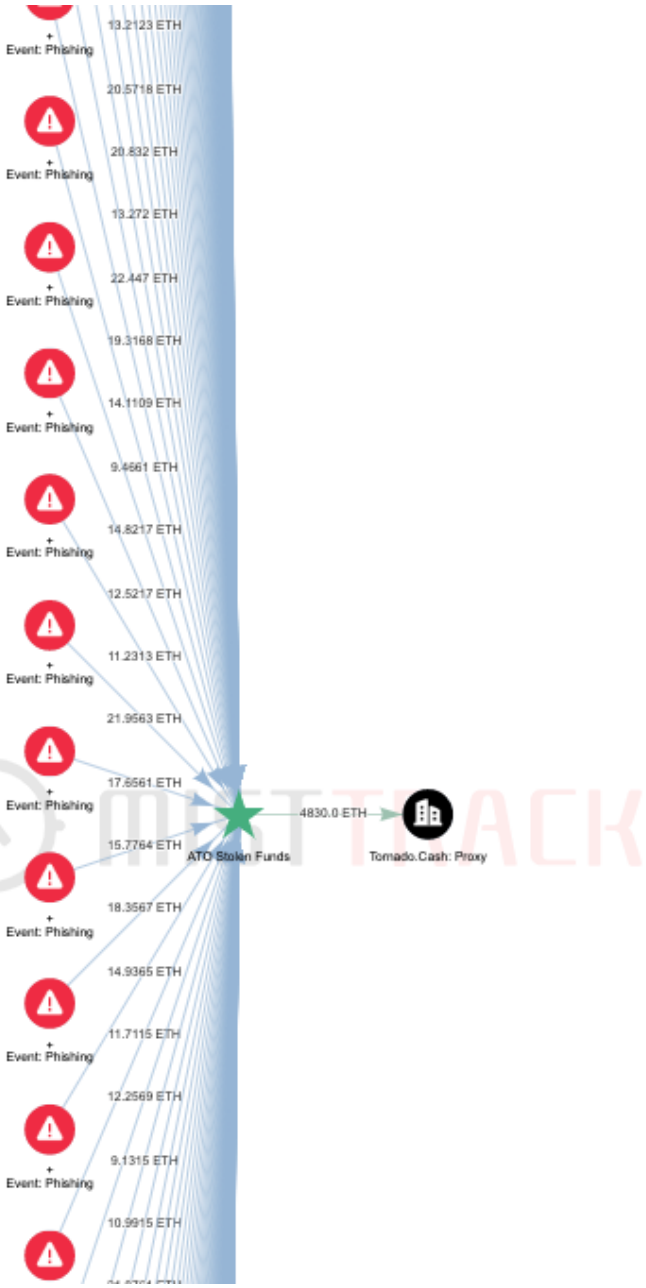
攻击手续费来源：无

资金转移：



（Crypto.com Hacker 资金转移时间线）

ETH 资金转移



（Crypto.com Hacker ETH 资金转移图）

ETH 资金转移表：

流向	流向资金

Tornado.Cash	4,830 ETH
Balance	1.1692 ETH

BTC 资金转移

BTC 资金转移表：

流向	流向资金
CryptoMixer	271 BTC
Balance	172.9322 BTC

3.3.6 Uniswap Phishing

黑客地址:0x09b5027ef3a3b7332ee90321e558bad9c4447afa(ETH **链**)

被盗时间：7 **月** 11 **日**

损失统计：3,278.8477 ETH、240.42 WBTC

攻击手续费来源：Tornado.Cash

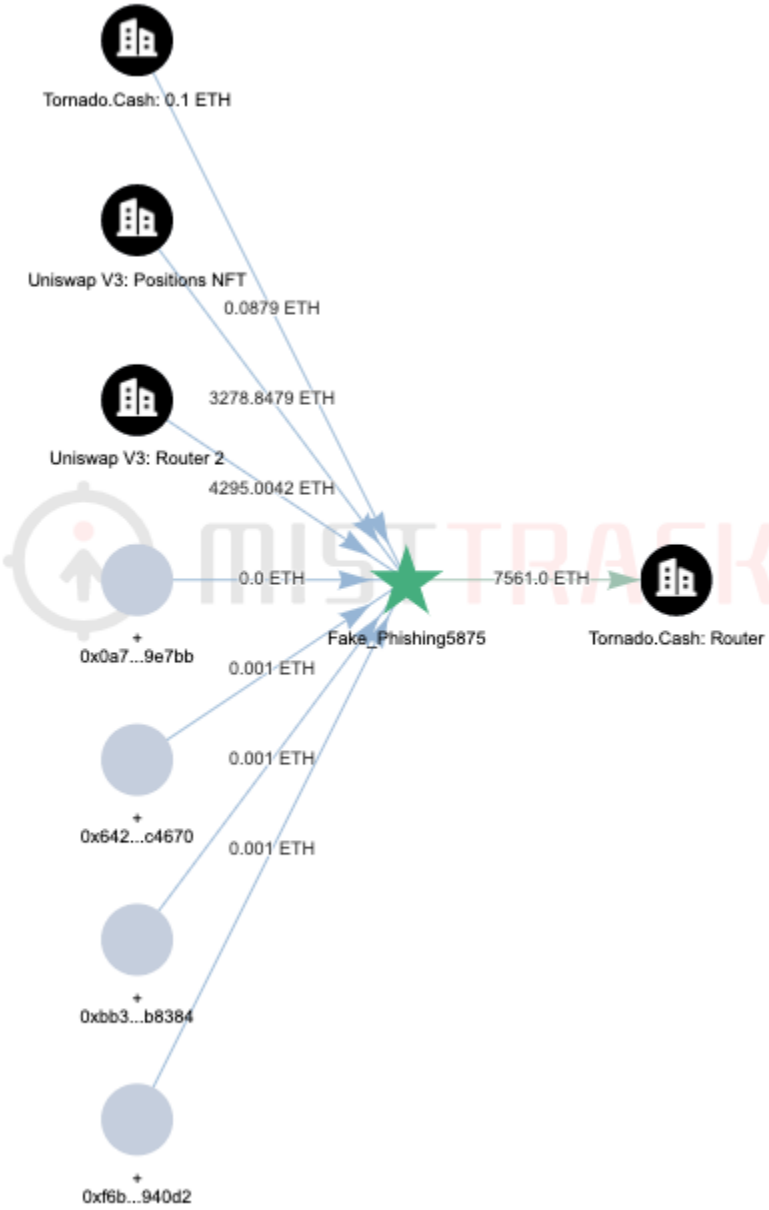
资金转移：



（Uniswap Phishing Hacker 资金转移时间线）

ETH 资金转移

黑客在洗钱的过程中通过 Uniswap 将 240.42 WBTC 兑换为 4,295.0041 ETH，洗钱的 ETH 资金共计 7,573.8518 ETH。



（Uniswap Phishing Hacker ETH 资金转移图）

ETH 资金转移表：

流向	流向资金
Tornado.Cash	7,561 ETH
Balance	9.46 ETH

3.3.7 ApeCoin 空投闪电贷套利

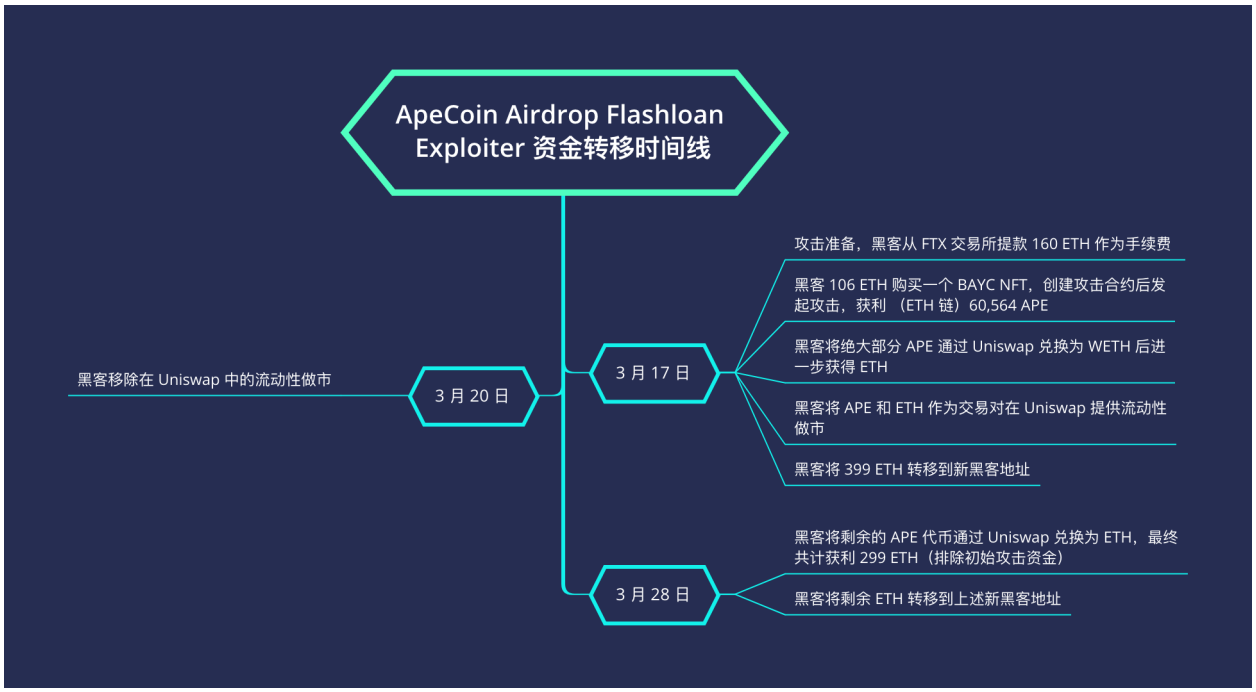
黑客地址:0x6703741e913a30d6604481472b6d81f3da45e6e8(ETH **链**)

被盗时间：3 **月** 17 **日**

损失统计：60,564 APE

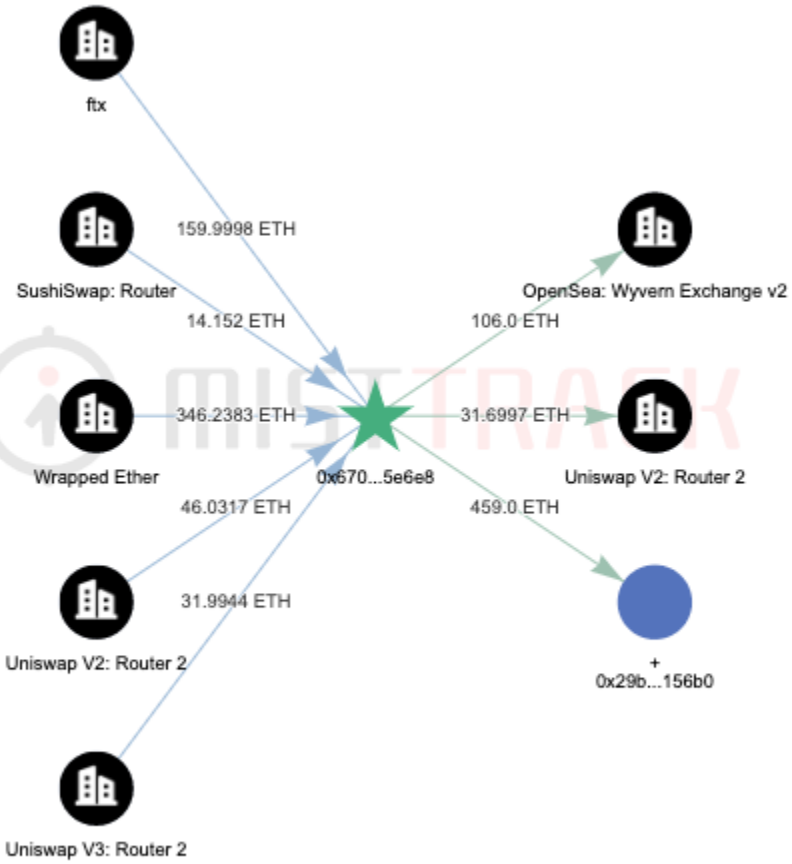
攻击手续费来源：FTX

资金转移：



（ApeCoin Airdrop Flashloan Exploiter 资金转移时间线）

ETH 资金转移



（ApeCoin Airdrop Flashloan Exploiter ETH 资金转移图）

ETH 资金转移表：

流向	流向资金
Balance	459 ETH

注：转移资金中包括攻击手续费剩余资金。

3.3.8 BAYC 官方 Discord 遭攻击

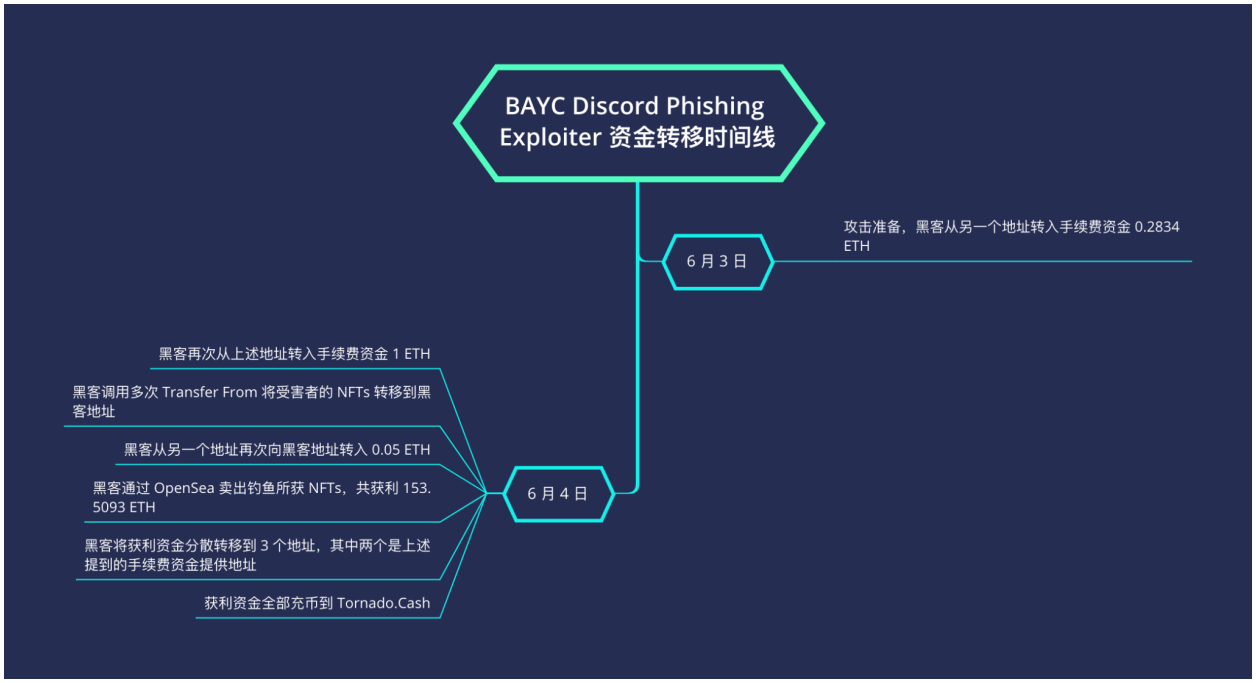
黑客地址：0x1079061d37f7f3fd3295e4aad02ece4a3f20de2d（ETH **链**）

被盗时间：6 **月** 4 **日**

损失统计：**价值超过** 145 **个** ETH （25.6 **万美元**）**的** NFTs

攻击手续费来源：从其他个人地址转入

资金转移：



（BAYC Discord Phishing Exploiter 资金转移时间线）

ETH 资金转移

ETH 资金转移表：

流向	流向资金
Tornado.Cash	153 ETH

3.3.9 FEGToken

此节将 5 月 15 日攻击的黑客称为黑客 1，将 5 月 16 日攻击的黑客称为黑客 2。

黑客地址：

0x73b359d5da488eb2e97990619976f2f004e9ff7c（**黑客** 1，ETH/BSC **链**）、

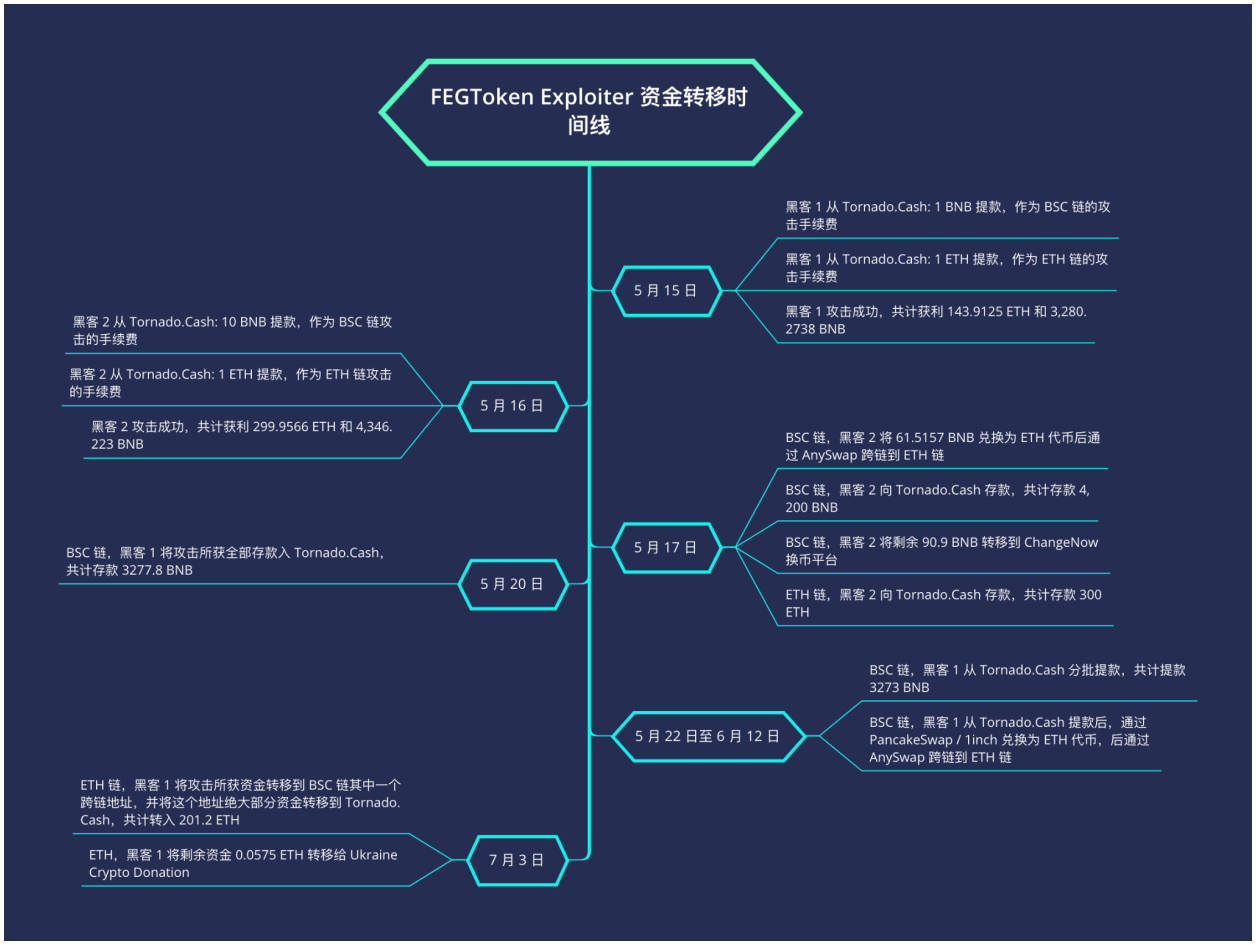
0xf99e5f80486426e7d3e3921269ffee9c2da258e2（**黑客** 2，ETH/BSC **链**）

被盗时间：5 **月** 15 **日**、5 **月** 16 **日**

损失统计：（**黑客** 1，ETH **链**）143.9125 ETH、（**黑客** 1，BSC **链**）3,280.2738 BNB、（**黑客** 2，ETH **链**）299.9566 ETH、（**黑客** 2，BSC **链**）4,346.223 BNB

攻击手续费来源：Tornado.Cash

资金转移：



（FEGToken Exploiter 资金转移时间线）

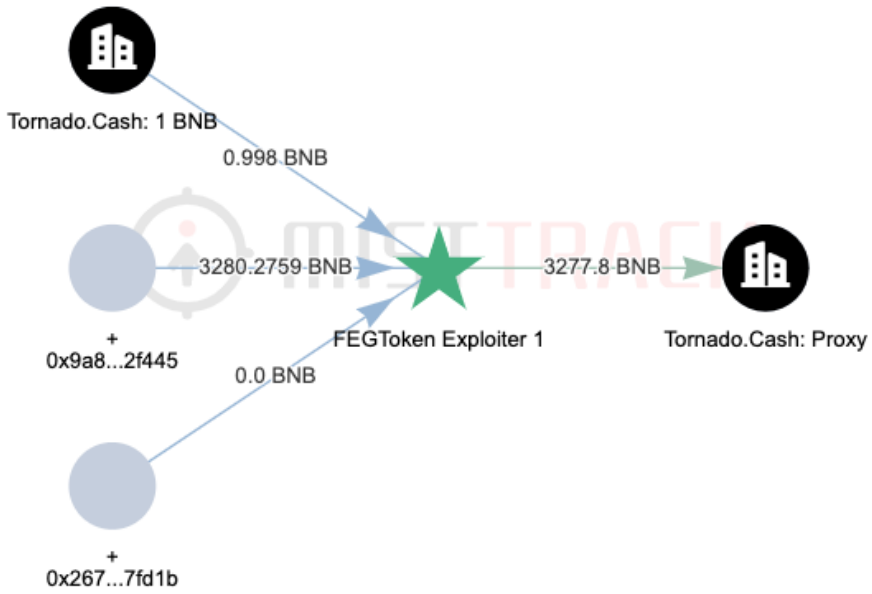
两次黑客攻击的关联性分析

根据以下链上痕迹分析：

- 两个黑客攻击手法不相同。
    - 黑客 1 重复调用攻击合约获利。
    - 黑客 2 单次调用攻击合约大额获利。
- 两个黑客洗钱手法不相同。
    - 黑客 1 将全部获利资金转入 Tornado.Cash。
    - 黑客 2 将大额资金转入 Tornado.Cash，将剩余资金转入 ChangeNOW。
- 两个黑客攻击/洗钱时间存在明显差别。

- 黑客 1 攻击时间在 5 月 15 日，洗钱时间在 5 月 20 日（BSC 链）和 7 月 3 日（ETH 链）。
- 黑客 2 攻击时间在 5 月 16 日，洗钱时间在 5 月 16 日。

黑客 1 资金转移



（FEGToken Exploiter 1 BSC 资金转移图）



（FEGToken Exploiter 1 ETH 资金转移图）

资金转移表：

链	流向	流向资金
BSC	Tornado.Cash	3,277.8 BNB
ETH	Tornado.Cash	144.8 ETH

黑客 1 BSC 链 Tornado.Cash 资金转移

在 BSC 链，黑客总计转入 3,277.8 BNB 到 Tornado.Cash ，经过分析，我们得出 FEGToken 黑客 1 的 Tornado.Cash 提款符合下列特征：

- 每次以 25/50 BNB 的数量通过 PancakeSwap/1inch 兑换为 BSC 链上的 ETH 代币，后通过 AnySwap 跨链到 ETH 链。
- 转移到 ETH 链上长时间不做进一步转移。

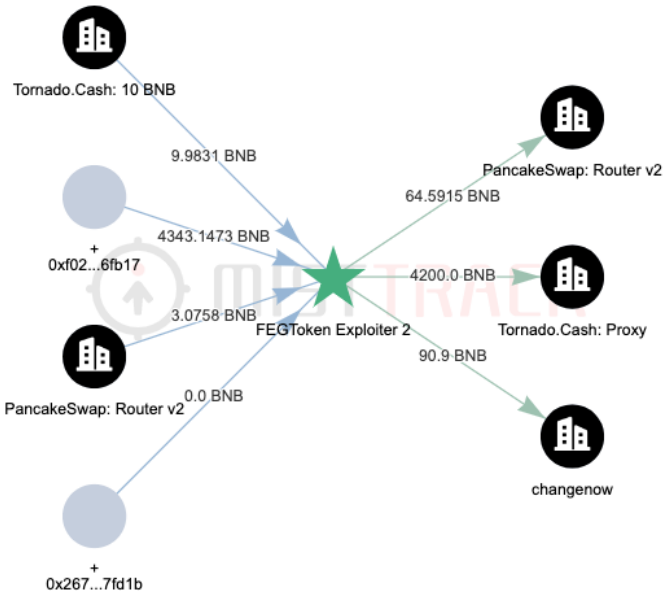
根据上述的转出特征，共计发现了黑客共计 3,273 BNB 数额的提款，黑客 1 于 BSC 链 Tornado.Cash 转出资金情况如下表：

流向	流向资金

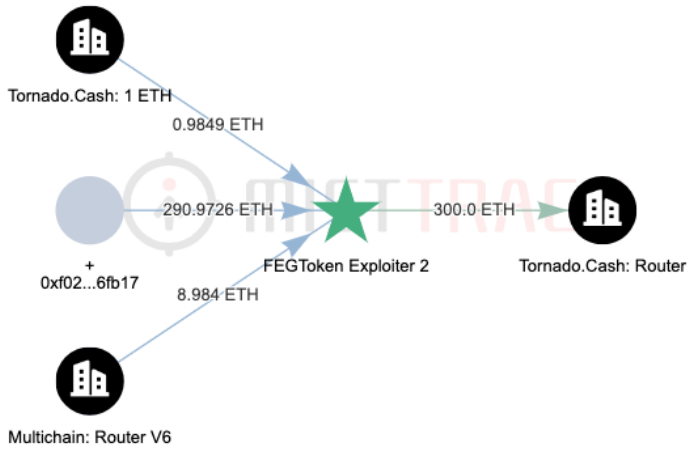
Tornado.Cash	56.5 ETH
Balance	476.9591 ETH

注:BSC 链上的资金都已通过 AnySwap 兑换成 ETH 在 ETH 链。

黑客 2 资金转移



（FEGToken Exploiter 2 BSC 资金转移图 ）



（FEGToken Exploiter 2 ETH 资金转移图）

资金转移表：

链	流向	流向资金
BSC	Tornado.Cash	4,200 BNB
BSC	ChangeNOW	90.9 BNB
ETH	Tornado.Cash	300 ETH

3.3.10 Optimism

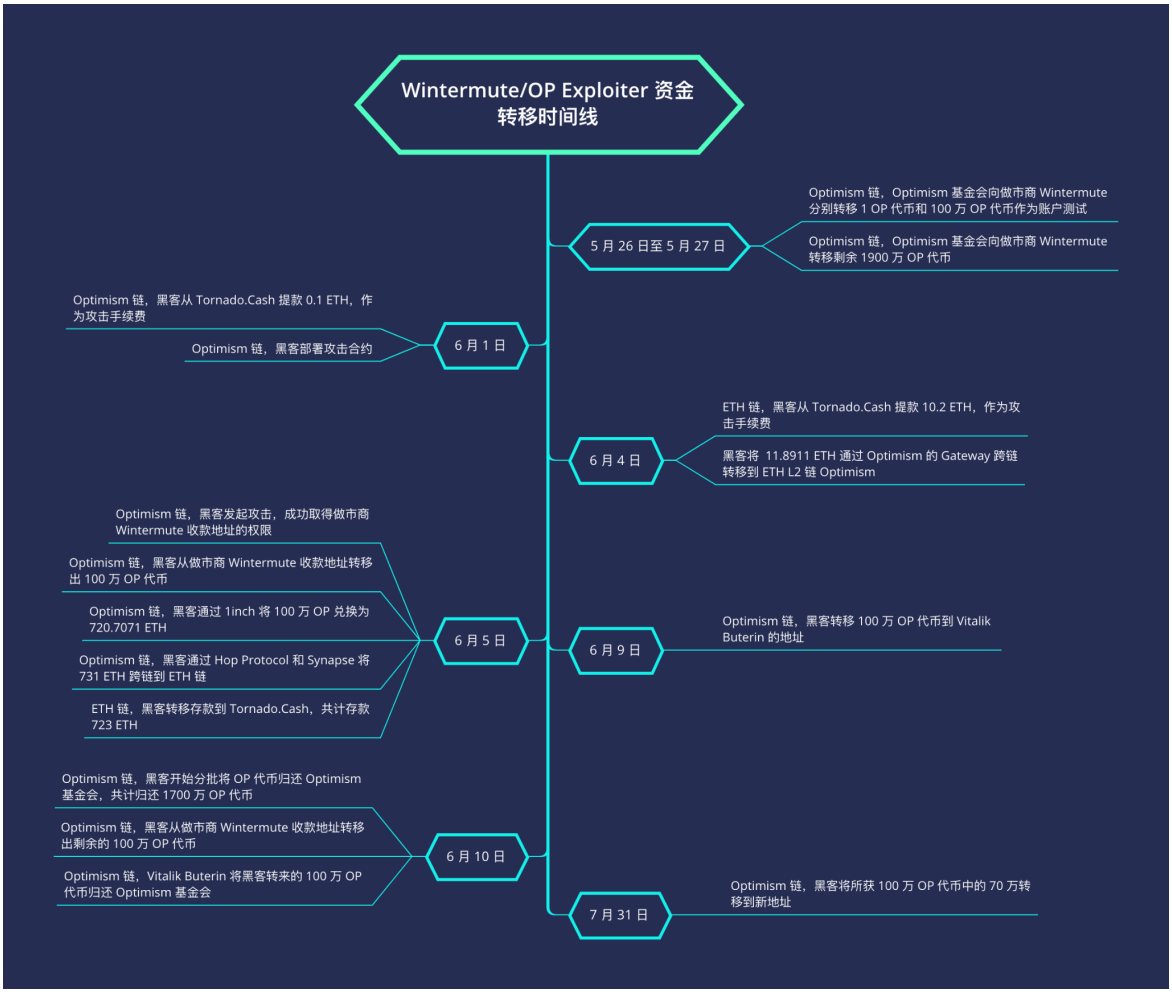
黑客地址:0x60B28637879B5a09D21B68040020FFbf7dbA5107（Optimism **链**）

被盗时间：6 **月** 5 **日**

损失统计：20,000,000 OP **代币**

攻击手续费来源：Tornado.Cash

资金转移：



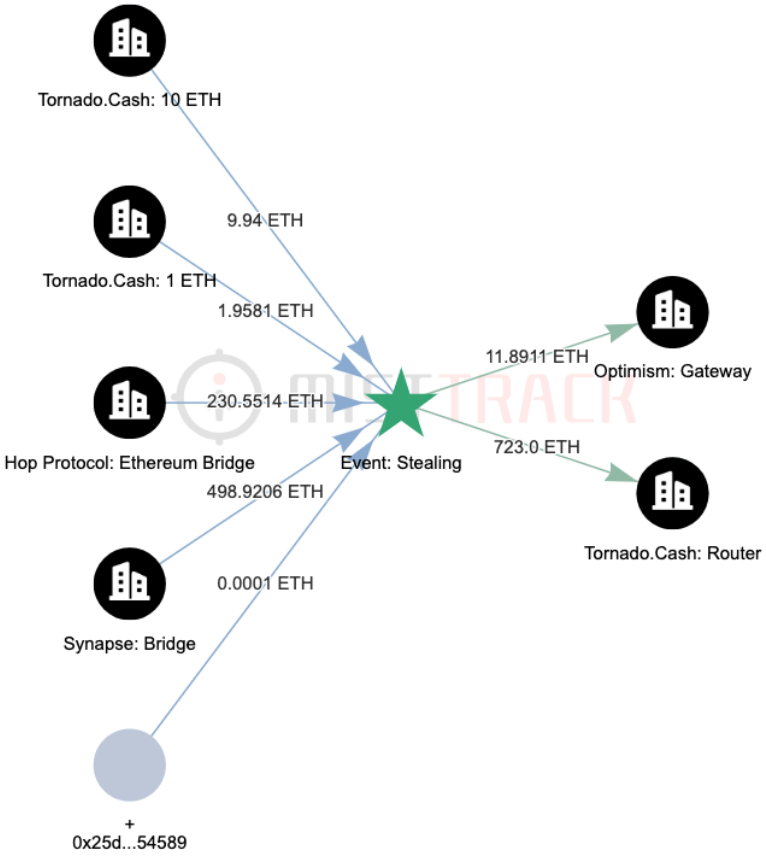
（Wintermute/OP Exploiter 资金转移时间线）

OP 代币资金转移

资金转移表：

流向	流向资金
归还 Optimism 基金会	17,000,000 OP
Vitalik Buterin（后归还 Optimism 基金会）	1,000,000 OP
通过 Hop Protocol 和 Synapse 跨链到 ETH 链	1,000,000 OP
Balance	1,000,000 OP

ETH 资金转移



（Wintermute/OP Exploiter ETH 资金转移图）

资金转移表：

流向	流向资金
Tornado.Cash	723 ETH
Balance	5.8744 ETH

注：转移资金中包括攻击手续费剩余资金。

3.3.11 MM.finance

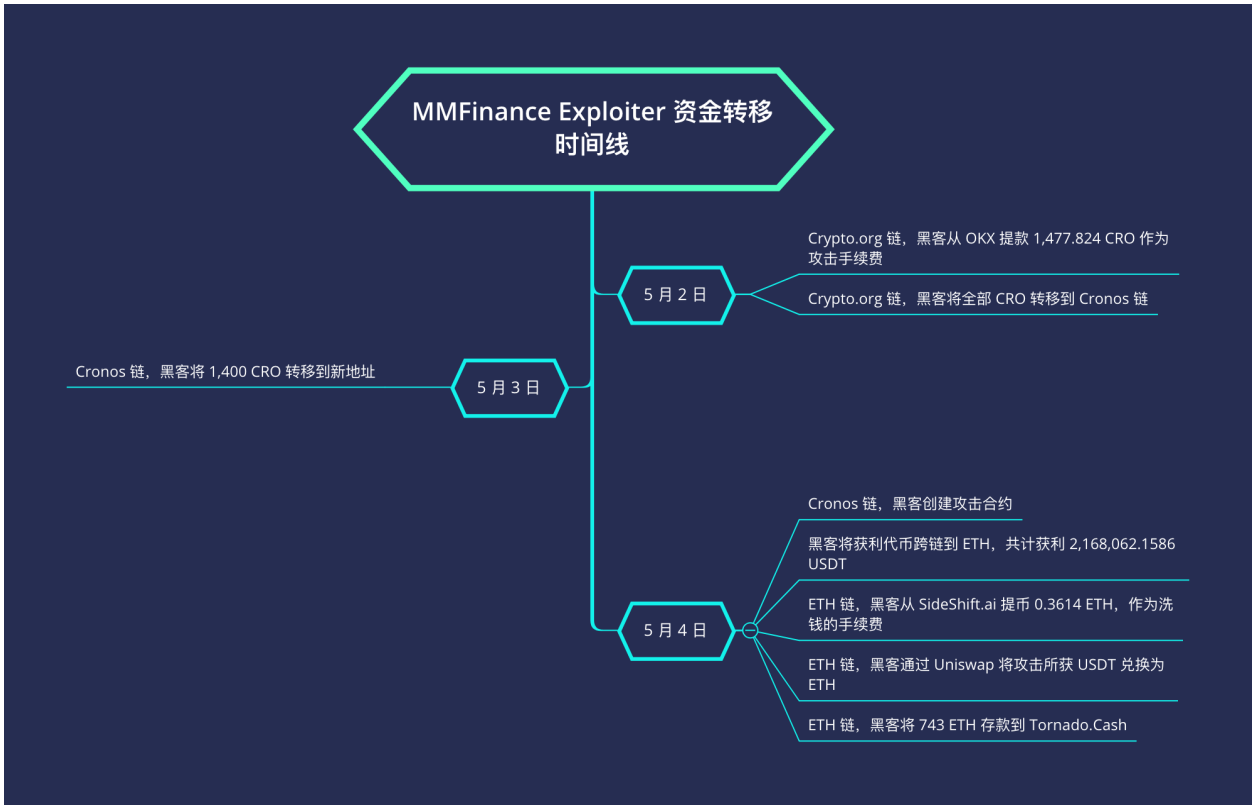
黑客地址：0xb3065fe2125c413e973829108f23e872e1db9a6b（Cronos 链）

被盗时间：5 月 4 日

损失统计：2,000,000 美元

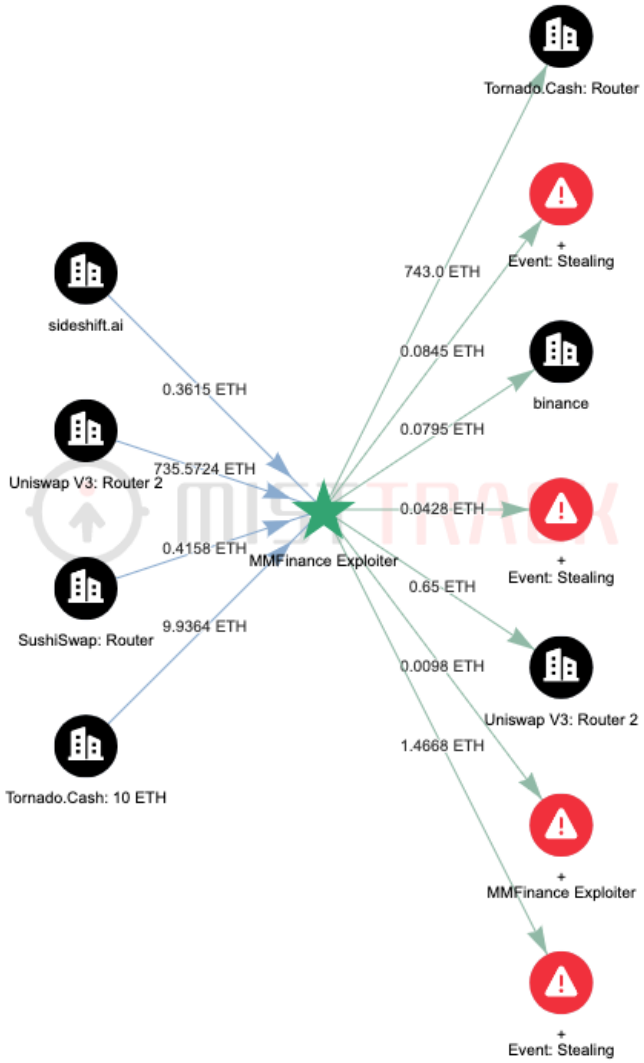
攻击手续费来源：OKX

资金转移：



（MMFinance Exploiter 资金转移时间线）

ETH 资金转移



（MMFinance Exploiter ETH 资金转移图）

资金转移表：

流向	流向资金
Tornado.Cash	743 ETH

四、总结

以上就是本次慢雾科技对区块链 2022 上半年安全事件及反洗钱情况的分析。总的来说，分为以下两点：

1、区块链安全事件层出不穷，攻击手法多样

根据统计，2022 上半年安全事件共 187 件，损失高达 19.76 亿美元。DeFi 安全事件就占了 53%（约 100 起），似乎已成为黑客的提款机。而在其中，影响力最大、被盗金额最高的项目几乎都集中在跨链桥。跨链桥资金量巨大、过于中心化，也因此成了黑客觊觎的目标。在上半年资产损失上亿的四起事件中，跨链桥领域就占了三起，分别是 Ronin Network、Wormhole、Harmony。

上半年常见攻击手法主要分为四类：由项目自身设计缺陷和各种合约漏洞引起的攻击；包含 Rug Pull、钓鱼攻击等手法的 Scam；由于私钥泄露引起的资产损失；前端恶意攻击。尤其是随着 Web3 蓬勃发展，针对 NFT 的钓鱼攻击手法花样百出，主要集中在针对 Discord/Twitter 等媒体平台被黑客攻击后发布钓鱼链接，用户一定要仔细辨别。

2、区块链典型安全事件与反洗钱分析

本报告对一些损失较大、发生次数较多、影响范围较广及攻击手法较新的安全事件进行了列举，包含被盗损失、攻击手法简述以及影响范围。

接着，使用 MistTrack 基础分析工具对 11 起典型安全事件展开了反洗钱分析，通过反洗钱分析清晰阐述“攻击手续费来源是什么”、“钱去了哪里”的问题，并创造性的提出了一种数据分析方法来分析 Tornado.Cash 和 ChipMixer 的提款。

在此过程中，我们发现洗钱流程集中在 ETH 链和 BTC 链上进行。ETH 链，74.6% 资金转移到 Tornado.Cash 以躲避追踪分析；BTC 链，48.9% 的资金转移到 ChipMixer 以躲避追踪分析。

BTC 链是特大型安全事件以及与 LAZARUS GROUP 黑客组织有关的事件洗钱的选择，因为相比较 ETH 链而言，BTC 链更具有匿名性、更多的混币工具选择，并且 LAZARUS GROUP 黑客组织在 BTC 链上洗钱更富有经验且更精通流程，这些有利于洗钱过程的顺利进行。

五、免责声明

本报告内容基于我们对区块链行业的理解、慢雾区块链被黑档案库 SlowMist Hacked 以及反洗钱追踪系统 MistTrack 的数据支持。但由于区块链的"匿名"特性，我们在此并不能保证所有数据的绝对准确性，也不能对其中的错误、疏漏或使用本报告引起的损失承担责任。 同时，本报告不构成任何投资建议或其他分析的根据。

本报告中若有疏漏和不足之处，欢迎大家批评指正。

六、关于我们



慢雾科技 (SlowMist) 是一家专注区块链生态安全的公司，成立于 2018 年 01 月，由一支拥有十多年一线网络安全攻防实战的团队创建，团队成员曾打造了拥有世界级影响力的安全工程。慢雾科技已经是国际化的区块链安全头部公司，主要通过"威胁发现到威胁防御一体化因地制宜的安全解决方案"服务了全球许多头部或知名的项目，已有商业客户上千家，客户分布在十几个主要国家与地区。

慢雾科技积极参与了区块链安全行标、国标及国际标准的推进工作，是国内首批进入工信部《2018 年中国区块链产业白皮书》的单位，是粤港澳大湾区"区块链与网络安全技术联合实验室"的三家成员单位之一，成立不到两年就获得「国家高新技术企业」认定。慢雾科技也是国家级数字文创规范治理生态矩阵首批协作发展伙伴。

慢雾科技的安全解决方案包括：安全审计、威胁情报(BTI)、漏洞赏金、防御部署、安全顾问等服务并配套有加密货币反洗钱(AML)、假充值漏洞扫描、漏洞监测(Vulpush)、被黑档案库(SlowMist Hacked)、智能合约防火墙(FireWall.X) 等 SAAS 型安全产品。基于成熟有效的安全服务及安全产品，慢雾科技联动国际顶级的安全公司，如 Akamai、BitDefender、FireEye、天际友盟、IPIP 等及海内外加密货币知名项目方、司法鉴定、公安单位等，从威胁发现到威胁防御上提供了一体化因地制宜的安全解决方案。慢雾科技在行业内曾独立发现并公布数多起通用高风险的区块链安全漏洞，得到业界的广泛关注与认可。给区块链生态带来安全感是慢雾科技努力的方向。

慢雾科技安全解决方案

安全服务



交易平台安全审计

超越渗透测试的私钥安全、业务安全等全方位的黑盒加灰盒安全审计



钱包安全审计

超越渗透测试的私钥安全、业务安全等全方位的黑盒加灰盒安全审计



链安全审计

针对区块链资金安全、共识安全等关键模块进行全方位的安全审计



智能合约安全审计

针对智能合约相关源码进行全方位的白盒安全审计



联盟链安全解决方案

从安全设计到安全审计再到安全监控及管理全周期进行联盟链安全保障



红队测试**(Red Teaming)**

超越渗透测试，针对人员、业务、办公等真实脆弱点进行攻击评估



安全监测

覆盖所有可能漏洞的动态安全监测体系，提供持续的、全方位的安全保障



区块链威胁情报

通过威胁情报整合，构建一个链上链下安全治理一体化的联合防御体系



漏洞赏金

设定业务范围和奖励标准，引入全球白帽黑客进行持续性的漏洞挖掘



防御部署

慢雾精选：因地制宜且体系化的防御方案、实施冷温热钱包安全加固等



安全顾问

全年性持续指导先导性安全体系建设工作，安全成为基建，防御先人一步



Hacking Time

每年一届聚焦于区块链安全的闭门培训和主题峰会



数字资产安全解决方案

GitHub 上持续开源开放“数字资产安全解决方案”，这是一件非常有益的事，欢迎贡献

安全产品



慢雾 **AML**

阻拦洗币，规避风险



MistTrack

面向 C 端用户的加密货币追踪分析平台



漏洞监测 **Vulpush**

实时掌握第一手安全漏洞情报



被黑档案库

区块链攻击事件一网打尽



假充值漏洞扫描器

交易平台安全充提的保障利器



官网

https://slowmist.com

Twitter

https://twitter.com/SlowMist_Team

Github

https://github.com/slowmist

Medium

https://slowmist.medium.com

Email

team@slowmist.com

微信公众号





SLOWMIST

Focusing on Blockchain Ecosystem Security